



DOCUMENTATION OFFICIELLE D'ADMINISTRATION SYSTÈME

Manuel Professionnel d'Administration Système

Gouvernance, infrastructure réseau, identité, systèmes
d'exploitation serveur, automatisation, virtualisation,
stockage, supervision ITIL, cybersécurité, continuité
d'activité et cloud.

ITIL v4

Réseau & TCP/IP

Active Directory

Linux & Windows Server

Docker & Kubernetes

Proxmox & VMware

Supervision

Cybersécurité

Cloud (AWS/Azure/GCP)

Jaslin Occius

Document confidentiel — usage interne Haitech Solutions

Table des matieres

- [Gouvernance et métier de l'administrateur système](#)
- [Gouvernance informatique et cadres de référence](#)
 - [Rôle de la gouvernance informatique](#)
 - [Fonctionnement : la chaîne de gouvernance](#)
 - [Prérequis organisationnels](#)
 - [Mise en œuvre étape par étape](#)
 - [Configuration : choisir son cadre de référence](#)
 - [Administration courante de la gouvernance](#)
 - [Outils et artefacts clés](#)
 - [Bonnes pratiques](#)
 - [Erreurs courantes](#)
 - [Résolution des blocages organisationnels](#)
 - [Recommandations de sécurité](#)
 - [Cas pratique — Haitech Solutions](#)
 - [Résumé du chapitre](#)
- [Rôles et responsabilités de l'administrateur système](#)
 - [Rôle de la fonction](#)
 - [Fonctionnement : la matrice de responsabilités](#)
 - [Prérequis pour exercer la fonction](#)
 - [Mise en place du rôle dans une nouvelle structure](#)
 - [Profils et niveaux de séniorité](#)
 - [Administration courante du rôle](#)
 - [Outils du quotidien](#)
 - [Bonnes pratiques](#)
 - [Erreurs courantes](#)
 - [Résolution des tensions de rôle](#)
 - [Recommandations de sécurité](#)
 - [Cas pratique — Haitech Solutions](#)
 - [Résumé du chapitre](#)
- [Architecture informatique d'entreprise](#)
 - [Rôle de l'architecture informatique](#)
 - [Fonctionnement : les couches d'architecture](#)
 - [Prérequis à une démarche d'architecture](#)

- [Mise en place d'une cartographie d'architecture](#)
- [Modèles d'architecture courants](#)
- [Administration courante de l'architecture](#)
- [Outils de cartographie](#)
- [Bonnes pratiques](#)
- [Erreurs courantes](#)
- [Diagnostic des problèmes d'architecture](#)
- [Recommandations de sécurité](#)
- [Cas pratique — Haitech Solutions](#)
- [Résumé du chapitre](#)
- [Documentation technique](#)
 - [Rôle de la documentation](#)
 - [Fonctionnement : les types de documentation](#)
 - [Prérequis](#)
 - [Mise en place d'un système de documentation](#)
 - [Structure recommandée d'un runbook](#)
 - [Administration courante](#)
 - [Outils recommandés](#)
 - [Bonnes pratiques](#)
 - [Erreurs courantes](#)
 - [Dépannage d'une documentation défaillante](#)
 - [Recommandations de sécurité](#)
 - [Cas pratique — Haitech Solutions](#)
 - [Résumé du chapitre](#)
- [Gestion des actifs informatiques et inventaire](#)
 - [Rôle de la gestion des actifs](#)
 - [Fonctionnement : le cycle de vie d'un actif](#)
 - [Prérequis](#)
 - [Mise en place d'un inventaire](#)
 - [Modèle de fiche d'inventaire](#)
 - [Administration courante](#)
 - [Outils d'inventaire et de découverte](#)
 - [Bonnes pratiques](#)
 - [Erreurs courantes](#)
 - [Dépannage : réconcilier un inventaire dérivé](#)
 - [Recommandations de sécurité](#)
 - [Cas pratique — Haitech Solutions](#)

- [Résumé du chapitre](#)
- [Fondamentaux réseau](#)
- [Le modèle OSI et l'architecture en couches](#)
 - [Rôle du modèle OSI](#)
 - [Fonctionnement : les sept couches](#)
 - [Prérequis pour exploiter ce modèle en diagnostic](#)
 - [Mise en pratique : lire un problème par couche](#)
 - [Configuration : où se situent les équipements courants](#)
 - [Administration courante : rattacher un ticket à une couche](#)
 - [Outils par couche](#)
 - [Bonnes pratiques](#)
 - [Erreurs courantes](#)
 - [Dépannage : tableau de correspondance symptôme → couche](#)
 - [Recommandations de sécurité](#)
 - [Cas pratique — Haitech Solutions](#)
 - [Résumé du chapitre](#)
- [TCP/IP : la suite de protocoles](#)
 - [Rôle de TCP/IP](#)
 - [Fonctionnement : le modèle TCP/IP en quatre couches](#)
 - [TCP contre UDP](#)
 - [Prérequis](#)
 - [Ports standards à connaître](#)
 - [Mise en pratique : diagnostiquer une connexion TCP/IP](#)
 - [Configuration : exemples de commandes courantes](#)
 - [Administration courante](#)
 - [Outils et commandes de référence](#)
 - [Bonnes pratiques](#)
 - [Erreurs courantes](#)
 - [Dépannage : symptôme → cause probable](#)
 - [Recommandations de sécurité](#)
 - [Cas pratique — Haitech Solutions](#)
 - [Résumé du chapitre](#)
- [Adressage IPv4 et calcul de sous-réseaux](#)
 - [Rôle de l'adressage IPv4](#)
 - [Fonctionnement : classes historiques et CIDR](#)
 - [Plages privées \(RFC 1918\), non routées sur Internet public](#)
 - [Prérequis : le calcul binaire de base](#)

- [Mise en place d'un plan d'adressage VLSM](#)
- [Modèle de plan d'adressage](#)
- [Administration courante](#)
- [Outils et commandes de calcul et de diagnostic](#)
- [Bonnes pratiques](#)
- [Erreurs courantes](#)
- [Dépannage des problèmes d'adressage](#)
- [Recommandations de sécurité](#)
- [Cas pratique — Haitech Solutions](#)
- [Résumé du chapitre](#)
- [IPv6 : structure et coexistence avec IPv4](#)
 - [Rôle d'IPv6](#)
 - [Fonctionnement : structure d'une adresse IPv6](#)
 - [Prérequis](#)
 - [Mise en œuvre d'une stratégie de coexistence](#)
 - [Configuration : exemples de commandes](#)
 - [Administration courante](#)
 - [Bonnes pratiques](#)
 - [Erreurs courantes](#)
 - [Dépannage](#)
 - [Recommandations de sécurité](#)
 - [Cas pratique — Haitech Solutions](#)
 - [Résumé du chapitre](#)
- [Topologies réseau et câblage structuré](#)
 - [Rôle des topologies réseau](#)
 - [Fonctionnement : les topologies courantes](#)
 - [Prérequis à la conception ou à l'audit d'une topologie](#)
 - [Mise en place : méthode de conception](#)
 - [Configuration : normes de câblage structuré](#)
 - [Organisation du rack et étiquetage](#)
 - [Administration courante](#)
 - [Bonnes pratiques](#)
 - [Erreurs courantes](#)
 - [Dépannage](#)
 - [Recommandations de sécurité](#)
 - [Cas pratique — Haitech Solutions](#)
 - [Résumé du chapitre](#)

- [VLAN et segmentation logique](#)
 - [Rôle des VLAN](#)
 - [Fonctionnement : ports access et ports trunk](#)
 - [Prérequis](#)
 - [Mise en place d'une segmentation VLAN](#)
 - [Configuration : exemples de commandes](#)
 - [Administration courante](#)
 - [Le Spanning Tree Protocol \(STP\) : prévenir les boucles](#)
 - [Bonnes pratiques](#)
 - [Erreurs courantes](#)
 - [Dépannage](#)
 - [Recommandations de sécurité](#)
 - [Cas pratique — Haitech Solutions](#)
 - [Résumé du chapitre](#)
- [Le routage : statique et dynamique](#)
 - [Rôle du routage](#)
 - [Fonctionnement : route statique contre routage dynamique](#)
 - [Protocoles de routage dynamique courants](#)
 - [Prérequis](#)
 - [Mise en place du routage inter-VLAN et inter-sites](#)
 - [Configuration : exemples de commandes](#)
 - [Administration courante](#)
 - [Distance administrative : quelle route gagne en cas de conflit](#)
 - [Bonnes pratiques](#)
 - [Erreurs courantes](#)
 - [Dépannage](#)
 - [Recommandations de sécurité](#)
 - [Cas pratique — Haitech Solutions](#)
 - [Résumé du chapitre](#)
- [NAT et PAT : translation d'adresses](#)
 - [Rôle du NAT](#)
 - [Fonctionnement : les types de NAT](#)
 - [Prérequis](#)
 - [Mise en place du NAT/PAT](#)
 - [Configuration : exemples de commandes](#)
 - [Administration courante](#)
 - [Bonnes pratiques](#)

- [Erreurs courantes](#)
- [Dépannage](#)
- [Recommandations de sécurité](#)
- [Cas pratique — Haitech Solutions](#)
- [Résumé du chapitre](#)
- [Services réseau essentiels](#)
- [DNS : le système de résolution de noms](#)
 - [Rôle du DNS](#)
 - [Fonctionnement : la hiérarchie DNS](#)
 - [Types d'enregistrements courants](#)
 - [Prérequis](#)
 - [Mise en place d'un service DNS interne](#)
 - [Configuration : exemples de commandes](#)
 - [Administration courante](#)
 - [Bonnes pratiques](#)
 - [Erreurs courantes](#)
 - [Dépannage](#)
 - [Recommandations de sécurité](#)
 - [Cas pratique — Haitech Solutions](#)
 - [Résumé du chapitre](#)
- [DHCP : attribution automatique d'adresses](#)
 - [Rôle du DHCP](#)
 - [Fonctionnement : le processus DORA](#)
 - [Prérequis](#)
 - [Mise en place d'un service DHCP](#)
 - [Configuration : exemples de commandes](#)
 - [Administration courante](#)
 - [La règle des 80/20 pour la redondance DHCP](#)
 - [Bonnes pratiques](#)
 - [Erreurs courantes](#)
 - [Dépannage](#)
 - [Recommandations de sécurité](#)
 - [Cas pratique — Haitech Solutions](#)
 - [Résumé du chapitre](#)
- [Pare-feu : filtrage et défense périmétrique](#)
 - [Rôle du pare-feu](#)
 - [Fonctionnement : générations de pare-feu](#)

- [Prérequis](#)
- [Mise en place d'une politique de pare-feu](#)
- [La DMZ \(zone démilitarisée\)](#)
- [Configuration : exemples de règles](#)
- [Administration courante](#)
- [Bonnes pratiques](#)
- [Erreurs courantes](#)
- [Dépannage](#)
- [Recommandations de sécurité](#)
- [Cas pratique — Haitech Solutions](#)
- [Résumé du chapitre](#)
- [Proxy et Reverse Proxy](#)
 - [Rôle du proxy et du reverse proxy](#)
 - [Fonctionnement comparé](#)
 - [Prérequis](#)
 - [Mise en place d'un reverse proxy](#)
 - [Configuration : exemples](#)
 - [Administration courante](#)
 - [Bonnes pratiques](#)
 - [Erreurs courantes](#)
 - [Dépannage](#)
 - [Recommandations de sécurité](#)
 - [Cas pratique — Haitech Solutions](#)
 - [Résumé du chapitre](#)
- [VPN : accès distant sécurisé](#)
 - [Rôle du VPN](#)
 - [Fonctionnement : les protocoles VPN courants](#)
 - [Prérequis](#)
 - [Mise en place d'un VPN nomade](#)
 - [Mise en place d'un VPN site-à-site](#)
 - [Configuration : exemples](#)
 - [Administration courante](#)
 - [Bonnes pratiques](#)
 - [Erreurs courantes](#)
 - [Dépannage](#)
 - [Recommandations de sécurité](#)
 - [Cas pratique — Haitech Solutions](#)

- [Résumé du chapitre](#)
- [Load Balancing : répartition de charge](#)
 - [Rôle du load balancing](#)
 - [Fonctionnement : niveaux et algorithmes](#)
 - [Algorithmes de répartition courants](#)
 - [Prérequis](#)
 - [Mise en place d'un répartiteur de charge](#)
 - [Configuration : exemples](#)
 - [Administration courante](#)
 - [Bonnes pratiques](#)
 - [Erreurs courantes](#)
 - [Dépannage](#)
 - [Recommandations de sécurité](#)
 - [Cas pratique — Haitech Solutions](#)
 - [Résumé du chapitre](#)

PARTIE I

Gouvernance et métier de l'administrateur système

Cette première partie pose les fondations non techniques sans lesquelles aucune infrastructure ne tient dans la durée : comment l'informatique se pilote, qui fait quoi, comment le système d'information s'organise, comment on documente ce qu'on construit, et comment on garde la trace de ce que l'on possède. Un administrateur système qui maîtrise parfaitement les commandes mais ignore ces fondations finit par construire une infrastructure ingouvernable — fonctionnelle un temps, mais impossible à faire évoluer, auditer ou transmettre à un successeur.

Cette partie couvre cinq chapitres : la gouvernance informatique et ses cadres de référence, les rôles et responsabilités de l'administrateur système, l'architecture informatique d'entreprise, la documentation technique, et la gestion des actifs informatiques.

Gouvernance informatique et cadres de référence

Rôle de la gouvernance informatique

La gouvernance informatique est l'ensemble des structures, processus et mécanismes de décision qui garantissent que les investissements et l'exploitation informatique servent réellement les objectifs de l'organisation, tout en maîtrisant les risques et les coûts. Ce n'est pas une couche bureaucratique ajoutée à la technique : c'est ce qui répond à la question que tout dirigeant finit par poser — « pourquoi dépense-t-on cela, et qui a décidé que c'était prioritaire ? ». Sans gouvernance, chaque décision technique (acheter un serveur, migrer vers le cloud, ouvrir un port) est prise isolément, sans traçabilité ni alignement avec la stratégie de l'entreprise.

Concrètement, la gouvernance répond à quatre questions permanentes : Qui décide ? Sur quels critères ? Avec quelles ressources ? Et comment vérifie-t-on que la décision a produit l'effet attendu ? Un système d'information bien gouverné rend ces quatre réponses visibles et traçables à tout moment, y compris plusieurs années après la décision initiale.

Fonctionnement : la chaîne de gouvernance

La gouvernance s'articule en cascade, de la stratégie d'entreprise jusqu'à l'exploitation quotidienne :

Niveau	Horizon	Instance typique	Livrables
Gouvernance d'entreprise	3-5 ans	Direction générale, conseil d'administration	Stratégie globale, budget IT

Niveau	Horizon	Instance typique	Livrables
Gouvernance IT (stratégique)	1-3 ans	Comité de pilotage IT (CODIR + DSI)	Schéma directeur, portefeuille de projets
Gouvernance IT (tactique)	1-12 mois	Comité des changements, comité sécurité	Plans de mise en œuvre, budgets annuels
Gestion opérationnelle	Quotidien	Équipe infrastructure / exploitation	Tickets, changements, incidents

Chaque niveau nourrit le suivant : une décision stratégique (« nous migrons vers le cloud ») se traduit en projets tactiques (choix du fournisseur, calendrier), puis en actions opérationnelles (migration effective, supervision post-migration). L'erreur la plus fréquente dans les petites structures est de fusionner ces niveaux : le même administrateur système décide seul de la stratégie, exécute et s'auto-valide, sans aucun regard extérieur ni traçabilité de la décision.

Prérequis organisationnels

- Un sponsor identifié au sein de la direction, capable d'arbitrer entre équipes et de débloquer un budget
- Une cartographie minimale des processus métier critiques (ce qui doit absolument fonctionner : facturation, réservation, paie...)
- Un inventaire des systèmes existants, même sommaire, avant toute tentative de gouvernance formelle
- Une culture d'entreprise qui tolère de documenter les décisions plutôt que de tout faire « à l'oral »

Attention

Tenter d'imposer un cadre de gouvernance lourd (COBIT complet, ITIL intégral) dans une structure de moins de 20 personnes sans sponsor ni culture de documentation aboutit presque toujours à un cadre ignoré au bout de trois mois. Mieux vaut un cadre minimal réellement suivi qu'un cadre complet abandonné.

Mise en œuvre étape par étape

1. **Cartographier l'existant** — Lister les systèmes, applications et infrastructures en place, avec leur criticité métier (impact si arrêt de 1h, 1 jour, 1 semaine).
2. **Identifier les instances de décision** — Définir qui valide un changement mineur, qui valide un changement majeur, qui arbitre en cas de désaccord.
3. **Choisir un cadre de référence adapté à la taille** — Voir tableau comparatif ci-dessous. Ne jamais adopter un cadre dans son intégralité dès le départ.
4. **Formaliser un nombre réduit de processus critiques** — Commencer par la gestion des changements et la gestion des incidents (Partie X), les deux processus dont l'absence se paie le plus vite.
5. **Mettre en place un tableau de bord minimal** — Nombre d'incidents, temps de résolution moyen, changements planifiés vs. changements en urgence : quatre indicateurs suffisent pour démarrer.
6. **Réviser à échéance fixe** — Revue trimestrielle du cadre : ce qui est suivi, ce qui est ignoré, ce qu'il faut simplifier.

Configuration : choisir son cadre de référence

Cadre	Objet principal	Complexité	Adapté à
ITIL v4	Gestion des services IT (incidents, changements, problèmes, catalogue de services)	Modulaire, adoptable par petits blocs	Toute structure à partir de quelques dizaines de postes
COBIT 2019	Gouvernance et audit IT, alignement stratégique et conformité	Élevée, orienté grands groupes et audit externe	Grandes entreprises, secteurs réglementés (banque, santé)
TOGAF	Architecture d'entreprise (urbanisation du SI à long terme)	Élevée	Organisations avec SI complexe multi-applicatif
ISO/IEC 20000	Certification de la gestion des services IT (proche d'ITIL)	Élevée (démarche de certification)	Prestataires IT cherchant une certification formelle

À savoir

Pour la majorité des PME et des prestataires comme Haitech Solutions, ITIL v4 adopté par blocs (gestion des incidents, des changements, catalogue de services) constitue le point d'entrée le plus réaliste. COBIT et TOGAF ne se justifient qu'à partir d'une taille ou d'une exigence réglementaire qui rendent l'audit externe obligatoire.

Administration courante de la gouvernance

Une fois en place, la gouvernance se pilote via des instances récurrentes et des indicateurs stables dans le temps, pour permettre la comparaison d'une période à l'autre :

Instance	Fréquence	Participants	Objet
Comité de pilotage IT	Trimestrielle	Direction, DSI/RSI, chefs de projet	Portefeuille de projets, budget, risques majeurs
Comité des changements (CAB)	Hebdomadaire	Équipe technique, product owner métier	Validation des changements à risque moyen/ élevé
Revue de sécurité	Mensuelle	RSSI ou référent sécurité, administrateur système	Vulnérabilités ouvertes, incidents de sécurité, correctifs en retard
Revue d'exploitation	Hebdomadaire	Équipe infrastructure	Incidents en cours, capacité, alertes de supervision

Outils et artefacts clés

- Registre des risques IT (feuille de calcul suffit au démarrage, outil GRC ensuite)
- Schéma directeur informatique (document de 5 à 15 pages, révisé annuellement)
- Charte des changements (qui peut valider quoi, Partie X)
- Tableau de bord d'indicateurs (nombre d'incidents, MTTR, taux de conformité des correctifs)
- Politique de sécurité de l'information (document cadre, Partie XI)

| Bonnes pratiques

💡 À appliquer systématiquement

- Documenter chaque décision structurante avec sa date, son auteur et sa justification, même de façon minimale
- Limiter le nombre d'indicateurs suivis à ce qui est réellement exploité : un tableau de bord surchargé finit ignoré
- Faire correspondre chaque système critique à un propriétaire métier identifié, pas seulement à un administrateur technique
- Réviser le cadre de gouvernance au moins une fois par an, en particulier après un incident majeur

| Erreurs courantes

⚠️ À éviter

- Copier intégralement un cadre lourd (COBIT, ITIL complet) sans l'adapter à la taille réelle de la structure
- Confier la gouvernance et l'exécution technique à la même personne sans aucun regard croisé
- Ne documenter la gouvernance qu'au moment d'un audit, puis abandonner la pratique ensuite
- Multiplier les comités sans lien réel entre eux, créant de la charge sans valeur ajoutée

| Résolution des blocages organisationnels

Les blocages de gouvernance ne se « dépannent » pas comme un serveur, mais suivent une logique de diagnostic similaire : identifier le symptôme, remonter à la cause racine, corriger la cause plutôt que le symptôme.

Symptôme observé	Cause racine probable	Action corrective
Les changements techniques se font sans validation	Absence de comité des changements ou comité non respecté	Formaliser un CAB léger, même hebdomadaire et court (30 min)
Personne ne sait qui décide en cas de panne majeure	Absence de plan d'astreinte et de matrice de décision	Rédiger une matrice RACI de crise (Chapitre 2)
Le budget IT est systématiquement dépassé	Absence de portefeuille de projets priorisé	Mettre en place une revue trimestrielle du portefeuille

Recommandations de sécurité

Sécurité

La gouvernance de la sécurité doit être visible au niveau du comité de pilotage IT, pas reléguée à un sujet purement technique. Un incident de sécurité majeur (fuite de données, ransomware) engage la responsabilité de la direction, pas seulement de l'administrateur système : la gouvernance sert précisément à documenter que les décisions de risque ont été prises en connaissance de cause, au bon niveau hiérarchique.

Cas pratique — Haitech Solutions

✦ Cas pratique

Sur les projets OTELA (PMS hôtelier multi-établissements) et ANTENN (régie de diffusion), le donneur d'ordre exprime ses besoins via des cahiers des charges détaillés, validés point par point plutôt que traités comme un bloc. C'est déjà une forme de gouvernance légère et efficace : chaque tranche de développement correspond à une décision explicite et tracée (« quel chantier prioriser ensuite »), avec un historique complet des choix effectués. En reproduisant ce principe à l'échelle de l'exploitation — un comité léger qui décide explicitement des priorités d'infrastructure plutôt que de laisser l'administrateur système arbitrer seul — Haitech Solutions peut faire évoluer cette pratique projet en véritable gouvernance IT sans changer fondamentalement de méthode de travail.

Résumé du chapitre

- La gouvernance informatique aligne les décisions IT sur les objectifs métier et rend les décisions traçables.
- Elle s'articule en cascade : stratégie d'entreprise, gouvernance IT stratégique et tactique, gestion opérationnelle.
- ITIL v4 adopté par blocs est le point d'entrée le plus réaliste pour une PME ou un prestataire de la taille de Haitech Solutions.
- Une gouvernance efficace repose sur peu d'indicateurs réellement suivis plutôt que sur un cadre complet abandonné.

Chapitre suivant : rôles et responsabilités de l'administrateur système.

PARTIE I · CHAPITRE 2

Rôles et responsabilités de

L'administrateur système

Rôle de la fonction

L'administrateur système est responsable de la disponibilité, de la performance, de la sécurité et de l'intégrité des systèmes informatiques d'une organisation. Ce rôle se situe à l'intersection de plusieurs disciplines : réseau, systèmes d'exploitation, sécurité, sauvegarde, et de plus en plus, automatisation et cloud. Contrairement à une idée reçue, la valeur de ce rôle ne se mesure pas au nombre de systèmes maîtrisés techniquement, mais à la fiabilité perçue par les utilisateurs métier : un bon administrateur système est largement invisible quand tout fonctionne, et extrêmement visible — et jugé — au moment d'un incident.

Fonctionnement : la matrice de responsabilités

Dans une petite structure, une seule personne peut cumuler tous les rôles ci-dessous. Dans une structure plus grande, ils se répartissent entre plusieurs profils. Formaliser cette matrice — même à une seule personne — évite les zones d'ombre où « personne ne savait que c'était à faire ».

Domaine	Responsable (R)	Accountable (A)	Consulté (C)	Informé (I)
Disponibilité des serveurs	Administrateur système	DSI / RSI	Éditeurs, hébergeur	Direction
Sauvegardes et restauration	Administrateur système	DSI / RSI	—	Direction, utilisateurs concernés
Sécurité périmétrique (pare-feu, VPN)	Administrateur système / réseau	RSSI ou DSI	Prestataire sécurité externe	Direction
Gestion des comptes	Administrateur système	RH (création/départ)	Manager du salarié	—

Domaine	Responsable (R)	Accountable (A)	Consulté (C)	Informé (I)
utilisateurs				
Continuité d'activité (PCA/PRA)	Administrateur système	Direction générale	Métiers critiques	Tout le personnel

À savoir

Cette matrice RACI (Responsible, Accountable, Consulted, Informed) est l'outil central de ce chapitre : R exécute, A rend des comptes et valide, C est consulté avant décision, I est informé après. Un même domaine ne doit jamais avoir deux « A » : cela crée systématiquement des conflits d'arbitrage.

Prérequis pour exercer la fonction

- Connaissances techniques transverses : réseau, systèmes Windows/Linux, virtualisation, sécurité de base
- Capacité à documenter et à transmettre (Chapitre 4) : la compétence individuelle ne suffit pas si elle n'est pas transmissible
- Rigueur procédurale, en particulier sur les changements en production
- Compréhension a minima des enjeux métier de l'organisation, pour prioriser correctement en cas d'incident

Mise en place du rôle dans une nouvelle structure

1. **Réaliser un état des lieux** — Inventaire des systèmes existants, des accès, des mots de passe hérités (Chapitre 5).
2. **Sécuriser les accès administrateur** — Reprendre le contrôle exclusif des comptes à privilèges avant toute autre action (Partie XI).
3. **Établir la matrice RACI** — Même minimale, formaliser qui décide de quoi dès les premières semaines.

4. **Définir le périmètre d'astreinte** — Horaires couverts, procédure d'escalade, seuils de criticité déclenchant une intervention hors heures ouvrées.
5. **Mettre en place les outils de base** — Système de tickets, dépôt de documentation, gestionnaire de mots de passe partagé.

Profils et niveaux de séniorité

Niveau	Périmètre typique	Autonomie de décision
Junior / Support N1	Assistance utilisateurs, tickets simples, exécution de procédures documentées	Faible : escalade systématique au-delà du connu
Administrateur système confirmé	Exploitation quotidienne, changements standards, diagnostic de niveau 2	Moyenne : décide seul dans le cadre validé
Administrateur système senior / Lead	Architecture, changements majeurs, astreinte de dernier niveau	Élevée : arbitre les cas non couverts par les procédures
Responsable infrastructure / DSI	Stratégie, budget, gouvernance (Chapitre 1)	Décisionnelle sur les investissements

Administration courante du rôle

- Revue hebdomadaire des tickets ouverts et des incidents récurrents
- Suivi des correctifs de sécurité en attente d'application (Partie XI)
- Vérification périodique des sauvegardes (test de restauration, pas seulement contrôle de la tâche planifiée)
- Mise à jour continue de la documentation à chaque changement effectué

Outils du quotidien

- Système de tickets (Jira Service Management, GLPI, Zendesk selon la taille)
- Gestionnaire de mots de passe d'équipe (Bitwarden, KeePass partagé, Vault)
- Dépôt de documentation versionné (wiki interne, ou dépôt Git pour les runbooks, Partie VI)
- Registre des changements (Partie X)

Bonnes pratiques

À appliquer systématiquement

- Ne jamais être le seul détenteur d'un accès critique : toujours prévoir un accès de secours documenté et sécurisé
- Documenter au moment de l'action, pas a posteriori de mémoire
- Séparer clairement compte personnel et compte à privilèges administratifs (Parties IV et XI)
- Formaliser par écrit toute dérogation exceptionnelle à une procédure, avec sa justification

Erreurs courantes

À éviter

- Le syndrome du « bus factor 1 » : toute la connaissance de l'infrastructure dans une seule tête, jamais documentée
- Confondre urgence perçue et urgence réelle, au détriment de la priorisation par criticité métier
- Accepter des changements en production hors procédure « juste cette fois », qui deviennent la norme
- Négliger la relation avec les métiers, réduisant l'IT à une fonction perçue comme uniquement technique

Résolution des tensions de rôle

Les conflits les plus fréquents entre administrateur système et reste de l'organisation portent sur la vitesse perçue (« pourquoi ça prend du temps ») et sur le risque perçu (« pourquoi refuser ce changement »). La matrice RACI et un registre des risques visibles (Chapitre 1) sont les deux meilleurs outils de désamorçage : ils rendent explicite ce qui, sinon, reste de l'ordre du jugement personnel non justifié.

Recommandations de sécurité

Sécurité

Le compte de l'administrateur système est la cible n°1 de toute attaque ciblée (Partie XI, PKI et Zero Trust). Appliquer systématiquement le principe du moindre privilège même à ce rôle : compte nominal pour les tâches quotidiennes, élévation temporaire tracée pour les tâches à privilèges, jamais de compte administrateur partagé entre plusieurs personnes.

Cas pratique — Haitech Solutions

✦ Cas pratique

Sur OTELA, le modèle RBAC (contrôle d'accès par rôle) distingue Réception, Ménage, Administrateur d'établissement et Administrateur de chaîne, avec un cloisonnement testé et vérifié empêchant un administrateur d'établissement de créer un compte de niveau chaîne, même en forçant les paramètres de la requête. C'est exactement la même logique que la matrice RACI de ce chapitre, appliquée au niveau applicatif plutôt qu'organisationnel : définir précisément qui peut faire quoi, et vérifier que la limite tient réellement, pas seulement dans l'interface.

Résumé du chapitre

- La matrice RACI formalise qui exécute, qui rend des comptes, qui est consulté et qui est informé sur chaque domaine.
- Un même domaine ne doit jamais avoir deux « Accountable ».
- Le principe du moindre privilège s'applique aussi au compte de l'administrateur système lui-même.
- La documentation (Chapitre 4) est ce qui transforme une compétence individuelle en actif transmissible.

Chapitre suivant : architecture informatique d'entreprise.

Architecture informatique d'entreprise

Rôle de l'architecture informatique

L'architecture informatique décrit comment les composants d'un système d'information (réseau, serveurs, applications, données) s'assemblent pour servir les besoins métier, aujourd'hui et dans les évolutions prévisibles. Une infrastructure sans architecture explicite fonctionne quand même, jusqu'au jour où elle doit évoluer : ajouter un site, migrer un serveur critique, absorber une charge multipliée par cinq. C'est à ce moment que l'absence de vision d'ensemble se paie le plus cher, sous forme de refontes d'urgence plutôt que d'évolutions planifiées.

Fonctionnement : les couches d'architecture

Couche	Contenu	Exemples
Architecture métier	Processus et besoins de l'organisation	Réservation, facturation, paie, relation client
Architecture applicative	Logiciels et services qui supportent les processus métier	ERP, CRM, messagerie, applications métier
Architecture des données	Modèles de données, flux, référentiels	Bases de données, entrepôts, référentiel client unique
Architecture technique / infrastructure	Serveurs, réseau, stockage, virtualisation, cloud	Objet de la majorité de ce manuel (Parties II à IX)

Ces couches se lisent de haut en bas pour la conception (le métier détermine les besoins applicatifs, qui déterminent les besoins techniques) et de bas en haut pour l'exploitation quotidienne, où l'administrateur système opère principalement sur la couche technique tout en gardant une vision des couches supérieures pour prioriser correctement.

| Prérequis à une démarche d'architecture

- Inventaire des applications et de leurs interdépendances (quelle application dépend de quelle base de données, de quel serveur)
- Connaissance des flux de données critiques et de leurs volumes
- Compréhension des contraintes de continuité (Partie XII) : quels systèmes ne peuvent tolérer aucune interruption

| Mise en place d'une cartographie d'architecture

1. **Recenser les applications** — Nom, éditeur/développeur, criticité métier, hébergement (on-premise, cloud), responsable.
2. **Recenser l'infrastructure sous-jacente** — Serveurs physiques/virtuels, bases de données, systèmes de stockage associés à chaque application.
3. **Cartographier les flux réseau** — Quel serveur communique avec quel autre, sur quel port, dans quel sens (Partie II).
4. **Documenter les dépendances critiques** — Identifier les points de défaillance unique (SPOF) : un seul serveur dont la panne arrête plusieurs applications.
5. **Formaliser des schémas de référence** — Un schéma d'architecture logique et un schéma d'architecture physique, tenus à jour à chaque changement structurant.

Modèles d'architecture courants

Modèle	Description	Cas d'usage typique
Monolithique centralisé	Une application, une base de données, un serveur (ou une paire pour la HA)	PME avec un seul site, faible complexité applicative
Architecture N-tiers	Séparation présentation / logique métier / données sur des serveurs distincts	Applications web métier de taille moyenne
Architecture distribuée multi-site	Systèmes répartis sur plusieurs sites avec réplication	Chaînes multi-établissements (cas OTELA multi-hôtel, ANTENN)
Architecture cloud hybride	Partie on-premise, partie cloud public, interconnectées	Organisations en transition vers le cloud (Partie XII)

Administration courante de l'architecture

- Mettre à jour les schémas à chaque ajout ou retrait de composant significatif
- Revoir l'architecture avant tout projet de croissance (nouveau site, nouvelle application critique)
- Identifier et traiter progressivement les points de défaillance unique restants

Outils de cartographie

- Outils dédiés : Lucidchart, draw.io (gratuit, fichiers versionnables), Archi (TOGAF, gratuit)
- CMDB pour l'inventaire détaillé et les dépendances (Chapitre 5 et Partie X)
- Diagrammes-as-code pour les schémas versionnés avec le code (Mermaid, PlantUML), pertinent pour les équipes déjà orientées Git (Partie VI)

Bonnes pratiques

À appliquer systématiquement

- Garder les schémas d'architecture à un niveau de détail lisible : un schéma illisible n'est jamais consulté
- Distinguer toujours schéma logique (comment ça fonctionne) et schéma physique (où c'est réellement installé)
- Traiter les SPOF identifiés par ordre de criticité métier, pas par facilité technique de correction
- Impliquer les responsables métier dans la validation de l'architecture des systèmes qui les concernent

Erreurs courantes

À éviter

- Laisser l'architecture uniquement dans la tête de celui qui l'a construite, sans schéma écrit
- Ajouter des composants sans jamais retirer ceux devenus obsolètes (dette d'architecture silencieuse)
- Concevoir une architecture cible idéale sans jamais planifier de chemin réaliste pour l'atteindre
- Ignorer les contraintes de bande passante et de latence entre sites dans une architecture distribuée

Diagnostic des problèmes d'architecture

Symptôme	Cause d'architecture probable	Piste de correction
Une panne isolée arrête plusieurs services	Point de défaillance unique non identifié	Cartographier les dépendances, planifier une redondance ciblée (Partie IX)
Les performances se dégradent avec la croissance des utilisateurs	Architecture non dimensionnée pour la montée en charge	Étude de capacité, envisager la répartition de charge (Partie III)
Chaque évolution applicative nécessite de tout retester	Couplage fort entre composants qui devraient être indépendants	Planifier un découplage progressif, pas une refonte immédiate

Recommandations de sécurité

Sécurité

L'architecture doit intégrer la sécurité dès la conception (« security by design »), pas en ajout final. La segmentation réseau par zones de confiance (Partie II, VLAN), l'isolement des systèmes exposés publiquement (Partie III, DMZ) et la limitation des flux au strict nécessaire entre couches applicatives sont des décisions d'architecture, pas des options de configuration ajoutables après coup sans refonte.

Cas pratique — Haitech Solutions

✦ Cas pratique

L'architecture multi-tenant d'OTELA illustre un choix d'architecture assumé et documenté : modèle « Silo » avec `resolveEtablissement` garantissant que la donnée d'un établissement ne peut jamais fuir vers un autre, même en cas de paramètre falsifié côté client. C'est une décision d'architecture des données (isolement par tenant) qui a des conséquences directes sur l'architecture technique (une base partagée avec filtrage systématique plutôt qu'une base par établissement). Documenter ce type de choix — et surtout la raison pour laquelle l'alternative a été écartée — est précisément ce qu'une cartographie d'architecture doit capturer pour rester utile dans deux ou trois ans.

Résumé du chapitre

- L'architecture s'organise en quatre couches : métier, applicative, données, technique.
- Une cartographie à jour est le meilleur outil pour anticiper les évolutions et identifier les points de défaillance unique.
- La sécurité se conçoit dès l'architecture, pas en ajout final.
- Documenter le pourquoi d'un choix d'architecture est aussi important que le schéma lui-même.

Chapitre suivant : documentation technique.

Documentation technique

Rôle de la documentation

La documentation technique est ce qui transforme une compétence individuelle en actif d'organisation. Un système parfaitement administré mais jamais documenté représente un risque opérationnel majeur : en cas d'absence, de départ ou d'incident touchant l'administrateur système lui-même, personne d'autre ne peut intervenir efficacement. La documentation n'est pas un livrable secondaire produit « quand on a le temps » : c'est une partie intégrante du travail d'administration, au même titre que la configuration elle-même.

Fonctionnement : les types de documentation

Type	Objectif	Fréquence de mise à jour	Exemple
Documentation d'architecture	Vue d'ensemble durable du système	À chaque changement structurant	Schémas réseau, cartographie applicative (Chapitre 3)
Procédures opérationnelles (runbooks)	Exécuter une tâche récurrente de façon fiable et reproductible	À chaque évolution de la procédure	Procédure de sauvegarde, de bascule de secours
Documentation de dépannage	Résoudre rapidement un incident connu	Après chaque incident significatif	Base de connaissance des pannes récurrentes

Type	Objectif	Fréquence de mise à jour	Exemple
Journal des changements	Tracer qui a changé quoi et pourquoi	À chaque changement	Registre des changements (Partie X)
Documentation d'onboarding	Permettre à un nouvel arrivant de devenir autonome	Semestrielle ou après refonte majeure	Guide de prise en main de l'infrastructure

Prérequis

- Un espace de stockage unique et accessible à toute l'équipe technique (pas de documentation éparpillée entre emails, fichiers locaux et mémoire individuelle)
- Une convention de nommage et de structure minimale, pour que deux documents traitant de sujets voisins se ressemblent
- Un mécanisme de contrôle de version, même simple (historique de wiki, dépôt Git)

Mise en place d'un système de documentation

1. **Choisir un outil unique** — Wiki interne (Confluence, Wiki.js, BookStack) ou dépôt Git avec fichiers Markdown, selon la maturité technique de l'équipe.
2. **Définir un squelette de document standard** — Objectif, prérequis, procédure pas à pas, points de vérification, contacts en cas de blocage.
3. **Documenter en priorité le plus critique** — Commencer par les procédures dont l'absence causerait le plus de dommage en cas d'indisponibilité de l'administrateur habituel.
4. **Intégrer la documentation au processus de changement** — Aucun changement significatif n'est considéré terminé tant que sa documentation n'est pas mise à jour (Partie X, gestion des changements).
5. **Auditer périodiquement l'exactitude** — Faire exécuter une procédure documentée par une personne qui ne l'a pas écrite, pour vérifier qu'elle est réellement suivable.

Structure recommandée d'un runbook

Section	Contenu
Objectif	Une phrase expliquant ce que fait la procédure et dans quel contexte l'utiliser
Prérequis	Accès, outils, informations nécessaires avant de commencer
Étapes	Actions numérotées, chacune vérifiable indépendamment
Vérification	Comment confirmer que la procédure a réussi
Rollback	Comment revenir en arrière si la procédure échoue en cours de route
Contact	Qui contacter en cas de blocage imprévu

Administration courante

- Revue de la documentation à chaque changement (voir étape 4 ci-dessus)
- Nettoyage périodique des documents obsolètes plutôt que leur accumulation indéfinie
- Formation des nouveaux arrivants directement via la documentation existante, pour en tester la qualité en conditions réelles

Outils recommandés

Outil	Type	Points forts
Wiki.js / BookStack	Wiki auto-hébergé	Gratuit, structuration hiérarchique, recherche intégrée

Outil	Type	Points forts
Confluence	Wiki d'entreprise (Atlassian)	Intégration native avec Jira, très répandu en entreprise
Dépôt Git + Markdown	Documentation as code	Versionné avec le code, historique complet, revue par pull request
Notion	Espace de travail documentaire	Flexible, bonne prise en main, adapté aux petites équipes

Bonnes pratiques

💡 À appliquer systématiquement

- Écrire la documentation immédiatement après avoir résolu un problème, pendant que le contexte est encore frais
- Préférer des captures d'écran ou des exemples de commandes réels à des descriptions purement théoriques
- Dater et signer chaque mise à jour significative de document
- Écrire pour un lecteur qui ne connaît pas déjà le contexte, pas pour soi-même six mois plus tard

| Erreurs courantes

À éviter

- Documenter une fois puis ne jamais mettre à jour, laissant la documentation dériver silencieusement de la réalité
- Une documentation trop théorique, sans étapes concrètes exécutables
- Multiplier les emplacements de stockage (email, disque local, wiki) sans source de vérité unique
- Documenter des mots de passe ou secrets en clair dans un wiki non chiffré (Partie XI, gestion des secrets)

| Dépannage d'une documentation défailante

Une documentation qui n'est jamais consultée est souvent un symptôme, pas une cause : elle indique généralement qu'elle est trop difficile à trouver, trop longue, ou perçue comme non fiable suite à des expériences passées où elle s'est révélée obsolète. La correction passe rarement par « écrire plus », mais par restructurer l'existant (le rendre plus court, plus cherchable, daté) et par restaurer la confiance via un premier audit de fiabilité.

Recommandations de sécurité

Sécurité

La documentation technique décrit souvent, en creux, l'architecture de sécurité d'un système. Elle doit donc être protégée avec un niveau d'accès cohérent avec sa sensibilité : accessible à toute l'équipe technique pour les procédures opérationnelles, mais restreinte pour les schémas d'architecture de sécurité détaillés ou tout document contenant des éléments d'authentification. Ne jamais publier de documentation technique sensible sur un espace public ou insuffisamment protégé.

Cas pratique — Haitech Solutions

Cas pratique

Le module Documents/KYC de BANKA et la documentation `docs/MAIL_SERVER_SETUP.md` de POSTA (configuration Postfix/Dovecot/OpenDKIM prête à déployer, rédigée avant même que le serveur ne soit provisionné) illustrent la bonne pratique centrale de ce chapitre : documenter une procédure avant ou pendant sa mise en œuvre, pas après coup de mémoire. Ce même réflexe — documenter le pourquoi d'une décision technique au moment où elle est prise plutôt que de compter sur la mémoire de l'équipe — est ce qui permet, des mois plus tard, de reprendre un chantier interrompu sans tout redécouvrir à partir de zéro.

Résumé du chapitre

- La documentation transforme une compétence individuelle en actif transmissible à l'organisation.
- Cinq types de documentation couvrent l'essentiel : architecture, runbooks, dépannage, changements, onboarding.

- Documenter au moment de l'action est plus fiable que documenter de mémoire après coup.
- Une documentation jamais consultée est un symptôme à corriger, pas une fatalité.

Chapitre suivant : gestion des actifs informatiques et inventaire.

PARTIE I · CHAPITRE 5

Gestion des actifs informatiques et inventaire

Rôle de la gestion des actifs

La gestion des actifs informatiques (IT Asset Management, ITAM) consiste à connaître à tout instant ce que l'organisation possède, où cela se trouve, qui en est responsable, et dans quel état de cycle de vie cela se situe. C'est un prérequis silencieux à presque toutes les autres disciplines de ce manuel : on ne peut pas sécuriser un serveur dont on ignore l'existence, planifier un renouvellement de licence qu'on ne sait pas expirer, ni évaluer l'impact d'un incident sans savoir quels systèmes en dépendent.

Fonctionnement : le cycle de vie d'un actif

Phase	Activités	Point de vigilance
Acquisition	Achat, réception, enregistrement initial dans l'inventaire	Enregistrer avant mise en service, pas après
Déploiement	Installation, configuration, affectation à un usage ou un utilisateur	Mettre à jour l'inventaire à chaque affectation

Phase	Activités	Point de vigilance
Exploitation	Utilisation courante, maintenance, mises à jour	Revue périodique de l'état réel vs. l'inventaire déclaré
Fin de vie	Retrait, décommissionnement, destruction sécurisée des données	Effacement sécurisé avant toute mise au rebut ou revente

Prérequis

- Un référentiel unique d'inventaire (feuille de calcul au minimum, outil ITAM/CMDB ensuite)
- Une convention de nommage cohérente pour tous les équipements (voir exemple Partie II, étiquetage réseau)
- Un processus d'entrée/sortie de matériel formalisé, même simple

Mise en place d'un inventaire

1. **Réaliser un état des lieux physique** — Recenser tout le matériel existant : serveurs, postes, réseau, périphériques, licences.
2. **Choisir un référentiel de données** — Colonnes minimales : identifiant, type, modèle, numéro de série, localisation, responsable, date d'acquisition, statut.
3. **Étiqueter physiquement le matériel** — Étiquette avec identifiant unique correspondant à l'inventaire, sur chaque équipement significatif.
4. **Recenser les licences logicielles** — Éditeur, nombre de licences achetées, nombre utilisées, date d'expiration ou de renouvellement.
5. **Mettre en place une revue périodique** — Rapprochement trimestriel entre inventaire déclaré et réalité constatée sur le terrain.

Modèle de fiche d'inventaire

Champ	Exemple
Identifiant	SRV-OTELA-01
Type	Serveur physique
Modèle / Référence	Dell PowerEdge R450
Numéro de série	ABCD1234
Localisation	Salle serveur, Rack A, U10-U12
Responsable	Administrateur système
Date d'acquisition	2026-01-15
Statut	En production
Garantie jusqu'au	2029-01-15
Systèmes hébergés	Base de données OTELA, backend applicatif

Administration courante

- Mettre à jour l'inventaire à chaque mouvement de matériel (entrée, sortie, déplacement, remplacement)
- Suivre les échéances de garantie et de fin de support (Partie X, gestion des mises à jour)
- Réconcilier périodiquement l'inventaire déclaratif avec un scan réseau automatisé (voir outils ci-dessous)

Outils d'inventaire et de découverte

Outil	Type	Usage
GLPI	ITAM/CMDB open source complet	Inventaire, gestion de parc, tickets intégrés :

Outil	Type	Usage
		bon point de départ PME
Snipe-IT	ITAM open source léger	Suivi de matériel et de licences, interface simple
Lansweeper / Nmap	Découverte réseau automatisée	Scan périodique pour détecter les équipements non déclarés (shadow IT)
NetBox	CMDB orientée infrastructure réseau	Documentation d'adressage IP, câblage, racks (complète Partie II)

Bonnes pratiques

À appliquer systématiquement

- Enregistrer un actif dans l'inventaire avant sa mise en production, jamais après
- Associer systématiquement une criticité métier à chaque actif serveur (Chapitre 3)
- Effacer les données de façon sécurisée avant toute cession ou mise au rebut de matériel
- Croiser régulièrement inventaire déclaratif et scan réseau pour détecter le matériel non déclaré

Erreurs courantes

À éviter

- Un inventaire tenu une seule fois puis jamais mis à jour, devenant rapidement obsolète
- Ignorer les licences logicielles dans l'inventaire, source fréquente de non-conformité (Partie X)
- Ne pas tracer le matériel personnel connecté au réseau de l'entreprise (BYOD non recensé)
- Mettre au rebut du matériel sans effacement sécurisé préalable des données

Dépannage : réconcilier un inventaire dérivé

Lorsqu'un inventaire s'est visiblement éloigné de la réalité (matériel introuvable, équipements non recensés découverts par hasard), la correction se fait par un scan de découverte réseau complet, comparé ligne à ligne à l'inventaire déclaratif, plutôt que par une reconstruction manuelle à partir de la mémoire de l'équipe, systématiquement plus lente et moins fiable.

Recommandations de sécurité

Sécurité

Le matériel non inventorié (shadow IT) est un angle mort de sécurité majeur : impossible d'appliquer une politique de correctifs, de durcissement ou de supervision à un système dont on ignore l'existence. Un scan de découverte réseau régulier fait partie intégrante d'une posture de sécurité de base, au même titre que la gestion des vulnérabilités (Partie XI).

Cas pratique — Haitech Solutions

✦ Cas pratique

Sur SHOPAY, une découverte fortuite en session a révélé qu'un serveur backend et un serveur frontend tournaient déjà en arrière-plan, zombies d'une session de travail antérieure jamais arrêtée : un exemple concret, quoique à petite échelle, de dérive entre ce qui est réellement déployé et ce qui est su ou documenté. À l'échelle d'une infrastructure de production comme celle visée par ce manuel, ce même phénomène (un service oublié, jamais inventorié, jamais surveillé) est précisément ce qu'un inventaire tenu à jour et un scan de découverte périodique permettent de prévenir avant qu'il ne devienne un incident de sécurité.

Résumé du chapitre

- La gestion des actifs suit un cycle de vie en quatre phases : acquisition, déploiement, exploitation, fin de vie.
- Un actif doit être enregistré avant sa mise en production, jamais après coup.
- Un scan de découverte réseau périodique révèle les écarts entre inventaire déclaré et réalité (shadow IT).
- Le matériel non inventorié est un angle mort de sécurité, pas seulement un problème de gestion.

Ceci conclut la Partie I. Partie suivante : fondamentaux réseau (modèle OSI, TCP/IP, IPv4, IPv6, VLAN, routage).

Fondamentaux réseau

Aucune administration système ne tient sans une maîtrise solide du réseau : c'est le tissu conjonctif qui relie chaque serveur, chaque poste, chaque service. Cette partie couvre les fondations théoriques indispensables (modèle OSI, TCP/IP) puis les briques concrètes que l'administrateur système configure et dépanne au quotidien : adressage IPv4 et IPv6, topologies et câblage, segmentation par VLAN, routage, et translation d'adresses (NAT/PAT).

Ces huit chapitres forment le socle sur lequel s'appuient directement les Parties III (services réseau : DNS, DHCP, pare-feu, VPN) et IV (identité et annuaire) : impossible de configurer un contrôleur de domaine ou un pare-feu sans comprendre d'abord comment les paquets circulent.

Le modèle OSI et l'architecture en couches

Rôle du modèle OSI

Le modèle OSI (Open Systems Interconnection, ISO 1984) découpe la communication réseau en sept couches indépendantes, chacune responsable d'une fonction précise et communiquant uniquement avec les couches immédiatement adjacentes. Son rôle n'est pas d'être implémenté tel quel (c'est TCP/IP, plus pragmatique, qui domine en pratique — Chapitre 7) mais de fournir un **langage commun de diagnostic** : quand un administrateur système dit « le problème est en couche 2 », tout technicien réseau comprend immédiatement qu'il s'agit d'un problème de commutation ou d'adressage MAC, pas de routage ou d'application.

Fonctionnement : les sept couches

#	Couche	Rôle	Unité de données	Exemples
7	Application	Interface avec les logiciels utilisateurs	Données	HTTP, DNS, SMTP, FTP
6	Présentation	Format, chiffrement, compression	Données	TLS/SSL, encodage (UTF-8, JPEG)
5	Session	Ouverture/maintien/fermeture de session	Données	Sessions TLS, NetBIOS
4	Transport	Livraison fiable ou rapide de bout en bout	Segment	TCP, UDP

#	Couche	Rôle	Unité de données	Exemples
3	Réseau	Adressage logique et routage entre réseaux	Paquet	IPv4, IPv6, ICMP
2	Liaison de données	Adressage physique local, détection d'erreurs	Trame	Ethernet, Wi-Fi, commutation (switch), VLAN
1	Physique	Transmission des bits sur le support	Bit	Câble cuivre, fibre optique, ondes radio

Moyen mnémotechnique

De la couche 1 à la couche 7 : « Please Do Not Throw Sausage Pizza Away » (Physique, Data link, Network, Transport, Session, Presentation, Application). En français, une variante courante : « Pour Livrer Rapidement, Transportez Sept Paquets Aujourd'hui ».

Prérequis pour exploiter ce modèle en diagnostic

- Connaître l'encapsulation : chaque couche ajoute son propre en-tête aux données de la couche supérieure en descendant (encapsulation), et les retire symétriquement en remontant (décapsulation) côté récepteur
- Savoir associer un symptôme observé à une couche probable (voir tableau de diagnostic ci-dessous)
- Disposer des outils de capture ou d'analyse adaptés à chaque couche (voir 8.7)

Mise en pratique : lire un problème par couche

1. **Couche 1 (Physique)** — Le câble est-il branché, le voyant du port est-il allumé, la fibre n'est-elle pas coudée au-delà du rayon de courbure minimal ?
2. **Couche 2 (Liaison)** — Le VLAN est-il correctement configuré sur le port, y a-t-il une boucle (tempête de broadcast), l'adresse MAC est-elle bien apprise par le switch ?
3. **Couche 3 (Réseau)** — L'adresse IP est-elle correcte, la passerelle par défaut répond-elle, une route existe-t-elle vers la destination ?
4. **Couche 4 (Transport)** — Le port TCP/UDP est-il ouvert côté serveur, un pare-feu ne bloque-t-il pas ce port en chemin ?
5. **Couches 5 à 7** — La session applicative s'établit-elle (certificat TLS valide, authentification acceptée, réponse applicative correcte) ?

Méthode

Diagnostiquer du bas vers le haut (couche 1 avant couche 7) évite de perdre du temps à déboguer une application qui « ne répond pas » alors que le câble réseau est simplement débranché. C'est la première question à se poser face à tout incident réseau signalé.

Configuration : où se situent les équipements courants

Équipement	Couche principale d'opération	Décision qu'il prend
Hub (obsolète)	1	Aucune — répète le signal électrique sur tous les ports
Switch (commutateur)	2 (certains modèles L3)	Vers quel port envoyer une trame, selon l'adresse MAC

Équipement	Couche principale d'opération	Décision qu'il prend
Routeur	3	Vers quel réseau envoyer un paquet, selon l'adresse IP
Pare-feu applicatif (NGFW)	3 à 7	Filtrage jusqu'au contenu applicatif (Partie III)
Répartiteur de charge (load balancer)	4 ou 7 selon le mode	Vers quel serveur backend envoyer la requête (Partie III)

Administration courante : rattacher un ticket à une couche

Un bon réflexe d'exploitation consiste à classer chaque incident réseau signalé par sa couche probable dès l'ouverture du ticket, pour orienter directement le bon outil de diagnostic et éviter les allers-retours entre équipes.

Outils par couche

Couche	Outils de diagnostic
1 — Physique	Testeur de câble, voyants de port, <code>ethtool</code> (Linux)
2 — Liaison	<code>show mac address-table</code> (Cisco), <code>arp -a</code> , analyseur de trames (Wireshark)
3 — Réseau	<code>ping</code> , <code>tracert</code> / <code>tracert</code> , <code>ip route</code> , <code>show ip route</code>
4 — Transport	<code>netstat</code> , <code>ss -tulpn</code> (Linux), <code>Test-NetConnection</code> (PowerShell), scanner de ports (<code>nmap</code>)

Couche	Outils de diagnostic
5 à 7 — Session/Présentation/Application	<code>curl -v</code> , navigateur avec outils développeur, journaux applicatifs

Bonnes pratiques

💡 À appliquer systématiquement

- Toujours diagnostiquer du bas vers le haut, sauf si un symptôme oriente déjà clairement vers une couche précise
- Documenter la couche identifiée dans le ticket d'incident, pour accélérer la résolution des cas similaires futurs
- Former les équipes support N1 à distinguer au minimum couche 1-2 (physique/liaison) de couche 3+ (réseau et au-delà), pour un premier tri efficace

Erreurs courantes

⚠️ À éviter

- Redémarrer un service applicatif en réflexe avant d'avoir vérifié la connectivité réseau de base (couches 1-3)
- Confondre un problème de résolution DNS (couche 7 applicative) avec un problème de routage IP (couche 3) — deux diagnostics très différents pour un même symptôme apparent (« le site ne répond pas »)
- Ignorer les couches 5-6 (session, présentation) dans le diagnostic TLS, alors qu'une majorité des échecs de connexion HTTPS s'y situent (certificat expiré, versions TLS incompatibles)

Dépannage : tableau de correspondance symptôme → couche

Symptôme	Couche probable	Premier réflexe
Aucun voyant sur le port switch	1	Vérifier le câble, tester un autre port
Le poste ne reçoit pas d'adresse IP	2-3 (DHCP, Partie III)	Vérifier le VLAN du port, le service DHCP
« Destination host unreachable » au ping	3	Vérifier la table de routage, la passerelle
Le ping passe mais l'application ne répond pas	4-7	Vérifier le port applicatif, le pare-feu, le service lui-même
Erreur de certificat dans le navigateur	6	Vérifier la validité et la chaîne du certificat TLS (Partie XI)

Recommandations de sécurité

Sécurité

La segmentation de sécurité s'opère à plusieurs couches simultanément et de façon complémentaire : VLAN et listes de contrôle d'accès de port en couche 2, filtrage par sous-réseau et ACL routées en couche 3, pare-feu avec inspection de contenu en couche 7. Une sécurité reposant sur une seule couche (par exemple uniquement un pare-feu périmétrique en couche 3-4, sans segmentation interne en couche 2) laisse un attaquant ayant franchi le périmètre libre de se déplacer latéralement sans aucune friction.

Cas pratique — Haitech Solutions

✦ Cas pratique

Sur REYINYON (plateforme de visioconférence WebRTC), un bug réseau conteneur-à-conteneur découvert en session illustre parfaitement l'intérêt du raisonnement par couches : LiveKit et le service d'enregistrement Egress communiquaient via `node_ip: 127.0.0.1`, une adresse de bouclage propre à chaque conteneur Docker (couche 3, adressage IP), inutilisable par Egress pour joindre le flux WebRTC tant que les deux conteneurs ne partageaient pas le même espace réseau. Le symptôme observé (« l'enregistrement ne démarre jamais ») se situait en apparence au niveau applicatif (couche 7), mais la cause racine était strictement une mauvaise configuration d'adressage en couche 3 — exactement le type de piège que le réflexe « diagnostiquer du bas vers le haut » permet d'éviter.

Résumé du chapitre

- Le modèle OSI structure la communication réseau en sept couches, du support physique à l'application.
- Diagnostiquer du bas vers le haut (couche 1 avant couche 7) est la méthode la plus efficace face à un incident réseau.
- Chaque équipement réseau opère principalement à une couche donnée : switch en couche 2, routeur en couche 3.
- La sécurité réseau doit se penser à plusieurs couches simultanément, jamais une seule.

Chapitre suivant : TCP/IP, la suite de protocoles réellement utilisée en production.

TCP/IP : la suite de protocoles

Rôle de TCP/IP

TCP/IP est la suite de protocoles réellement déployée sur Internet et sur la quasi-totalité des réseaux d'entreprise — contrairement au modèle OSI (Chapitre 6), qui reste avant tout un outil pédagogique et de diagnostic. TCP/IP se condense en quatre couches pratiques plutôt que sept, et c'est ce modèle que configurent concrètement les administrateurs système : adresses IP, ports, protocoles de transport.

Fonctionnement : le modèle TCP/IP en quatre couches

Couche TCP/IP	Correspondance OSI	Rôle	Protocoles clés
Accès réseau	1-2	Transmission physique et adressage local	Ethernet, Wi-Fi (802.11), ARP
Internet	3	Adressage logique et routage	IPv4, IPv6, ICMP
Transport	4	Livraison de bout en bout	TCP, UDP
Application	5-7	Protocoles applicatifs	HTTP/HTTPS, DNS, SMTP, SSH, FTP

TCP contre UDP

Critère	TCP	UDP
Connexion	Orientée connexion (poignée de main à 3 temps)	Sans connexion
Fiabilité	Garantie (accusés de réception, retransmission)	Aucune garantie
Ordre des paquets	Préservé	Non garanti
Vitesse	Plus lent (overhead de fiabilité)	Plus rapide
Cas d'usage typique	HTTP/HTTPS, SSH, transferts de fichiers, bases de données	DNS, streaming vidéo/voix, jeux en ligne, VoIP

À savoir

La poignée de main TCP à 3 temps (« three-way handshake ») fonctionne ainsi : le client envoie un paquet SYN, le serveur répond SYN-ACK, le client confirme par ACK. Ce mécanisme garantit que les deux parties sont prêtes à communiquer avant tout échange de données — et c'est aussi la cible d'une attaque classique par déni de service (SYN flood, Partie XI).

| Prérequis

- Comprendre la notion de port : un numéro (0 à 65535) qui identifie un service précis sur une machine, permettant à plusieurs services de coexister sur la même adresse IP
- Connaître les ports standards des services les plus courants (tableau ci-dessous)

- Savoir lire une adresse de socket (IP:Port), l'identifiant unique d'une connexion réseau

Ports standards à connaître

Port	Protocole	Service
20-21	TCP	FTP (données/contrôle)
22	TCP	SSH
25	TCP	SMTP (envoi de mail)
53	TCP/UDP	DNS
67-68	UDP	DHCP
80	TCP	HTTP
123	UDP	NTP (synchronisation horaire)
143 / 993	TCP	IMAP / IMAPS
389 / 636	TCP	LDAP / LDAPS
443	TCP	HTTPS
445	TCP	SMB
465 / 587	TCP	SMTPS / soumission SMTP
3306	TCP	MySQL/MariaDB
3389	TCP	RDP (Bureau à distance Windows)
5432	TCP	PostgreSQL

⚠ Attention

Les ports 0 à 1023 sont dits « privilégiés » (well-known ports) : sur les systèmes Unix/Linux, seul un processus root (ou disposant de la capability `CAP_NET_BIND_SERVICE`) peut ouvrir un service en écoute sur l'un de ces ports. Une application qui tente d'écouter sur le port 80 sans privilège échoue avec une erreur de permission — cause fréquente de confusion pour un administrateur débutant.

Mise en pratique : diagnostiquer une connexion TCP/IP

1. **Vérifier la couche Internet (IP)** — `ping <adresse-ip>` confirme la joignabilité au niveau IP.
2. **Vérifier le chemin emprunté** — `tracert <destination>` (Linux/macOS) ou `tracert <destination>` (Windows) liste chaque routeur traversé.
3. **Vérifier qu'un port est ouvert côté serveur** — `ss -tulpn` (Linux) ou `netstat -ano` (Windows) liste les ports en écoute localement.
4. **Vérifier l'accessibilité d'un port distant** — `Test-NetConnection -ComputerName <hote> -Port <port>` (PowerShell) ou `nc -zv <hote> <port>` (Linux).
5. **Vérifier le contenu applicatif** — `curl -v https:// ...` affiche le détail de la négociation TLS et de la réponse HTTP.

Configuration : exemples de commandes courantes

```
# Linux – état des connexions et ports en écoute
ss -tulpn

# Linux – table de routage
ip route show

# Linux – configuration d'une interface
ip addr add 192.168.10.10/24 dev eth0
ip link set eth0 up

# Windows PowerShell – équivalents
Get-NetTCPConnection -State Listen
Get-NetRoute
New-NetIPAddress -InterfaceAlias "Ethernet" -IPAddress 192.168.10.10 -Pref
```

Administration courante

- Maintenir à jour un tableau des ports ouverts par serveur, aligné avec l'inventaire des applications (Partie I, Chapitre 5)
- Surveiller les connexions établies inhabituelles (port ou destination inconnue) comme indicateur précoce de compromission (Partie XI)
- Vérifier périodiquement que seuls les ports réellement nécessaires sont exposés (durcissement, Partie XI)

Outils et commandes de référence

Outil	Plateforme	Usage
<code>ping</code> / <code>ping -t</code>	Toutes	Test de joignabilité IP de base
<code>tracert</code> / <code>tracert</code>	Linux/macOS / Windows	Chemin emprunté par les paquets

Outil	Plateforme	Usage
<code>ss</code> / <code>netstat</code>	Linux / Windows	Connexions et ports en écoute
<code>nmap</code>	Toutes (outil tiers)	Scan de ports, découverte réseau (Partie I, Chapitre 5)
<code>Wireshark</code> / <code>tcpdump</code>	Toutes / Linux	Capture et analyse de trames en détail
<code>curl</code> / <code>Invoke-WebRequest</code>	Toutes / Windows	Test applicatif HTTP(S) en ligne de commande

Bonnes pratiques

💡 À appliquer systématiquement

- Toujours tester la connectivité de bas en haut : IP, puis port, puis contenu applicatif
- Préférer UDP pour les flux temps réel tolérants à la perte (voix, vidéo), TCP pour tout ce qui exige l'intégrité des données
- Documenter les ports utilisés par chaque application interne dans la cartographie d'architecture (Partie I, Chapitre 3)

Erreurs courantes

⚠ À éviter

- Confondre un port fermé (refus explicite, réponse rapide) et un port filtré (aucune réponse, timeout) — deux diagnostics réseau différents
- Oublier qu'un pare-feu peut bloquer un port en sortie (egress) et pas seulement en entrée (ingress)
- Négliger la MTU (taille maximale de paquet) sur les liens VPN ou tunnel, cause fréquente de connexions qui s'établissent mais se bloquent sur de gros transferts

Dépannage : symptôme → cause probable

Symptôme	Cause probable	Vérification
<code>ping</code> réussit, application ne répond pas	Port fermé ou service arrêté côté serveur	<code>ss -tulpn</code> sur le serveur, <code>Test-NetConnection</code> côté client
Connexion lente puis coupée sur gros transfert	Problème de MTU sur un tunnel VPN	Tester avec <code>ping -f -l <taille></code> (Windows) pour trouver la MTU effective
<code>tracert</code> s'arrête à un saut intermédiaire	Pare-feu bloquant ICMP sur ce routeur (souvent normal)	Vérifier avec un test de port direct plutôt que <code>tracert</code> seul

Recommandations de sécurité

Sécurité

Appliquer le principe du moindre privilège aux ports exposés : chaque port ouvert est une surface d'attaque potentielle. Un audit périodique des ports en écoute sur chaque serveur (via `nmap` en scan interne ou `ss` / `netstat` en local) doit systématiquement pouvoir justifier chaque port ouvert par un service métier réel — tout port ouvert sans justification claire doit être fermé (Partie XI, durcissement).

Cas pratique — Haitech Solutions

Cas pratique

La quasi-totalité des projets du portefeuille (BANKA, GESCOM, LAKAY, OTELA...) suivent la même convention de ports backend/frontend dédiés par projet (par exemple 4007/3008 pour OTELA), documentée systématiquement. Cette discipline — attribuer et documenter un port fixe par service plutôt que de laisser le système en choisir un au hasard — évite les collisions lorsque plusieurs projets tournent simultanément sur la même machine de développement, un problème concrètement rencontré sur SHOPAY où des serveurs backend et frontend oubliés en arrière-plan occupaient des ports sans que personne ne le sache (Partie I, Chapitre 5).

Résumé du chapitre

- TCP/IP condense le modèle OSI en quatre couches pratiques : accès réseau, Internet, transport, application.
- TCP garantit la fiabilité et l'ordre ; UDP privilégie la vitesse sans garantie, adapté au temps réel.
- Chaque service réseau s'identifie par un couple adresse IP + port ; connaître les ports standards accélère le diagnostic.

- Un audit régulier des ports ouverts est une pratique de sécurité de base, pas seulement d'exploitation.

Chapitre suivant : l'adressage IPv4, des classes historiques au calcul de sous-réseaux moderne (CIDR).

PARTIE II · CHAPITRE 8

Adressage IPv4 et calcul de sous-réseaux

Rôle de l'adressage IPv4

Une adresse IPv4 identifie de façon unique une interface réseau sur un réseau IP, au moyen de 32 bits représentés en notation décimale à quatre octets (par exemple **192.168.10.25**). Maîtriser le découpage en sous-réseaux (subnetting) est la compétence la plus structurante de ce chapitre : c'est elle qui permet de dimensionner un réseau ni trop large (gaspillage d'adresses, domaine de broadcast trop grand) ni trop étroit (croissance impossible sans re-découpage).

Fonctionnement : classes historiques et CIDR

Le découpage historique en classes A/B/C est aujourd'hui obsolète en pratique, remplacé par le CIDR (Classless Inter-Domain Routing), mais reste indispensable à connaître pour comprendre les plages réservées.

Classe	Plage réseau	Masque par défaut	Hôtes max	Usage historique
A	1.0.0.0 – 126.0.0.0	/8 (255.0.0.0)	~16,7 millions	Très grands réseaux
B	128.0.0.0 – 191.255.0.0	/16 (255.255.0.0)	~65 000	Réseaux moyens

Classe	Plage réseau	Masque par défaut	Hôtes max	Usage historique
C	192.0.0.0 – 223.255.255.0	/24 (255.255.255.0)	254	Petits réseaux

Plages privées (RFC 1918), non routées sur Internet public

Plage	Notation CIDR	Usage typique
10.0.0.0 – 10.255.255.255	10.0.0.0/8	Grands réseaux d'entreprise
172.16.0.0 – 172.31.255.255	172.16.0.0/12	Réseaux moyens, souvent conteneurs/Docker
192.168.0.0 – 192.168.255.255	192.168.0.0/16	Petits réseaux, PME, domicile

Prérequis : le calcul binaire de base

Chaque octet d'une adresse IPv4 vaut de 0 à 255 (8 bits). Un masque de sous-réseau détermine quelle partie de l'adresse identifie le réseau et quelle partie identifie l'hôte. Le CIDR note ce masque par le nombre de bits à 1 (par exemple **/24** = 24 bits de réseau, 8 bits d'hôte).

CIDR	Masque décimal	Hôtes utilisables	Usage typique
/30	255.255.255.252	2	Liaison point à point (routeur-routeur)
/29	255.255.255.248	6	Très petit segment
/28	255.255.255.240	14	Petit VLAN de service
/27	255.255.255.224	30	Petit VLAN départemental
/26	255.255.255.192	62	VLAN départemental moyen

CIDR	Masque décimal	Hôtes utilisables	Usage typique
/25	255.255.255.128	126	VLAN de taille moyenne
/24	255.255.255.0	254	VLAN standard PME

💡 Calcul rapide du nombre d'hôtes

Nombre d'hôtes utilisables = $2^{(\text{bits d'hôte})} - 2$. Les « -2 » correspondent à l'adresse réseau (tous les bits d'hôte à 0) et à l'adresse de broadcast (tous les bits d'hôte à 1), toutes deux réservées et non attribuables à un équipement.

Mise en place d'un plan d'adressage VLSM

Le VLSM (Variable Length Subnet Mask) permet de découper un réseau en sous-réseaux de tailles différentes selon le besoin réel de chaque segment, plutôt que d'imposer partout le même masque.

1. **Recenser le besoin réel de chaque segment** — Nombre d'hôtes actuels, plus une marge de croissance raisonnable (généralement 30 à 50 %).
2. **Trier les segments du plus grand au plus petit besoin** — Allouer d'abord les plus gros blocs évite la fragmentation de l'espace d'adressage.
3. **Attribuer un bloc CIDR à chaque segment** — Choisir le plus petit CIDR qui couvre le besoin plus la marge.
4. **Documenter le plan** — Réseau, masque, passerelle, plage DHCP, adresses statiques réservées (voir tableau modèle ci-dessous).
5. **Réserver systématiquement les 10 à 20 premières adresses** — Pour les équipements à IP fixe (passerelle, switches, serveurs), avant la plage DHCP dynamique.

Modèle de plan d'adressage

VLAN	Nom	Réseau/CIDR	Passerelle	Plage DHCP	Hôtes max
10	Administration	192.168.10.0/24	192.168.10.1	.50 – .200	251
20	Serveurs	192.168.20.0/25	192.168.20.1	Statique uniquement	126
30	Wi-Fi employés	192.168.30.0/24	192.168.30.1	.50 – .240	251
40	Invités	192.168.40.0/26	192.168.40.1	.10 – .60	62
99	Gestion (switches, AP)	192.168.99.0/27	192.168.99.1	Statique uniquement	30

Administration courante

- Tenir à jour le tableau des adresses statiques réservées (Partie I, Chapitre 5 — inventaire)
- Vérifier périodiquement le taux d'occupation de chaque plage DHCP, signal d'alerte avant saturation
- Documenter tout changement de plan d'adressage dans le registre des changements (Partie X)

Outils et commandes de calcul et de diagnostic

```
# Linux – afficher les interfaces et adresses
ip addr show

# Linux – calculer un sous-réseau (paquet ipcalc)
ipcalc 192.168.10.0/26

# Windows PowerShell – afficher la configuration IP
Get-NetIPConfiguration
Get-NetIPAddress -AddressFamily IPv4

# Windows – configuration IP classique
ipconfig /all
```

À savoir

Des calculatrices de sous-réseaux en ligne ou des outils comme `ipcalc` (Linux) évitent les erreurs de calcul manuel, en particulier sur des masques non standards (/27, /29). Cela reste utile de savoir calculer à la main pour comprendre ce que l'outil produit et détecter une incohérence.

Bonnes pratiques

À appliquer systématiquement

- Toujours prévoir une marge de croissance de 30 à 50 % lors du dimensionnement d'un sous-réseau, jamais piler au plus juste
- Réserver une plage cohérente et documentée pour les adresses statiques, distincte de la plage DHCP
- Éviter les chevauchements de plages entre sites, en particulier avant tout projet d'interconnexion VPN site-à-site (Partie III)
- Utiliser des VLAN de gestion dédiés (99 dans l'exemple ci-dessus) pour l'administration des équipements réseau eux-mêmes

Erreurs courantes

À éviter

- Dimensionner un sous-réseau exactement à la taille actuelle sans aucune marge, forçant un re-découpage douloureux dès la première croissance
- Utiliser le même plan d'adressage 192.168.1.0/24 par défaut sur tous les sites d'une organisation multi-site, rendant toute interconnexion VPN impossible sans renumérotation complète
- Oublier de soustraire l'adresse réseau et l'adresse de broadcast dans le calcul du nombre d'hôtes utilisables
- Placer un serveur critique dans la plage DHCP dynamique plutôt qu'en adresse statique documentée

Dépannage des problèmes d'adressage

Symptôme	Cause probable	Vérification
Le poste reçoit une adresse 169.254.x.x (APIPA)	Aucun serveur DHCP accessible	Vérifier le service DHCP (Partie III), le VLAN du port
Deux équipements ont la même adresse IP (conflit)	Adresse statique mal réservée ou hors de la plage DHCP exclue	Vérifier la réservation dans le plan d'adressage
Un site ne peut pas joindre un autre site en VPN	Chevauchement de plages d'adressage entre les deux sites	Comparer les plans d'adressage, renuméroter si besoin

Recommandations de sécurité

Sécurité

Un plan d'adressage structuré par fonction (administration, serveurs, invités, gestion des équipements) est un prérequis direct à la segmentation de sécurité par VLAN (Chapitre 12) : impossible d'appliquer une politique de pare-feu cohérente (« les invités ne peuvent joindre que Internet ») sans que les invités disposent déjà d'un sous-réseau clairement isolé des autres usages.

Cas pratique — Haitech Solutions

✦ Cas pratique

Le manuel de formation réseau déjà produit pour Jaslin ([livrables/formations/manuel-reseau-entreprise/](#)) documente un plan d'adressage VLSM complet à huit VLAN pour une PME type, avec la même logique que ce chapitre : réserver les adresses basses aux équipements statiques, dimensionner chaque VLAN selon son usage réel (caméras en `/24` statique, invités en plage DHCP dédiée). Ce même plan, transposé à l'infrastructure interne de Haitech Solutions, constitue un point de départ directement réutilisable plutôt qu'à reconcevoir de zéro.

Résumé du chapitre

- Le CIDR remplace en pratique les classes A/B/C historiques pour un découpage flexible en sous-réseaux.
- Le nombre d'hôtes utilisables se calcule par $2^{(\text{bits d'hôte})} - 2$.
- Un plan d'adressage VLSM documenté, avec marge de croissance, évite les re-découpages d'urgence.
- Un plan d'adressage structuré par fonction est le prérequis direct de la segmentation VLAN (Chapitre 12).

Chapitre suivant : IPv6, structure et coexistence avec IPv4.

IPv6 : structure et coexistence avec IPv4

Rôle d'IPv6

IPv6 répond à l'épuisement des adresses IPv4 (32 bits, ~4,3 milliards d'adresses, insuffisant face à la croissance des objets connectés) en offrant un espace d'adressage sur 128 bits, pratiquement inépuisable. Pour l'administrateur système, IPv6 n'est plus un sujet théorique : les systèmes d'exploitation modernes l'activent par défaut, de nombreux fournisseurs d'accès et fournisseurs cloud le déploient nativement, et l'ignorer complètement expose à des angles morts de configuration et de sécurité (un service accessible en IPv6 alors que seul le pare-feu IPv4 a été durci, par exemple).

Fonctionnement : structure d'une adresse IPv6

Une adresse IPv6 s'écrit en huit groupes de quatre chiffres hexadécimaux séparés par `:`, par exemple `2001:0db8:0000:0042:0000:8a2e:0370:7334`. Deux règles de simplification s'appliquent :

- Les zéros non significatifs de chaque groupe peuvent être omis (`0db8` devient `db8`)
- Une unique séquence de groupes entièrement à zéro peut être remplacée par `::` (une seule fois par adresse)

L'exemple ci-dessus se simplifie ainsi en `2001:db8:0:42:0:8a2e:370:7334`.

Type d'adresse	Préfixe	Portée	Équivalent IPv4
Unicast global	2000::/3	Routable sur Internet	Adresse publique

Type d'adresse	Préfixe	Portée	Équivalent IPv4
Unique local (ULA)	fc00::/7	Routable en interne uniquement	Plages privées RFC 1918
Lien-local	fe80::/10	Un seul segment réseau, non routée	169.254.0.0/16 (APIPA)
Multicast	ff00::/8	Diffusion à un groupe d'interfaces	224.0.0.0/4
Loopback	::1/128	La machine elle-même	127.0.0.1

À savoir

IPv6 n'a pas d'adresse de broadcast : la fonction est remplacée par le multicast, plus efficace (seuls les hôtes réellement intéressés traitent le paquet). ARP disparaît également, remplacé par NDP (Neighbor Discovery Protocol), qui fonctionne au-dessus d'ICMPv6.

| Prérequis

- Comprendre que le préfixe IPv6 standard alloué à un site est généralement un **/48** ou **/56**, et que chaque sous-réseau utilise ensuite un **/64** — la subdivision fine façon IPv4 (VLSM sur mesure) n'a pas la même utilité, l'espace étant surabondant
- Connaître les mécanismes d'auto-configuration (SLAAC — Stateless Address Autoconfiguration) qui permettent à un hôte de se configurer sans serveur DHCP
- Identifier les services de l'infrastructure existante qui écoutent déjà en IPv6 par défaut (souvent activé nativement sur Windows Server et les distributions Linux modernes)

Mise en œuvre d'une stratégie de coexistence

1. **Auditer l'existant** — Vérifier si IPv6 est déjà actif sur les serveurs et postes, même sans configuration explicite (`ip -6 addr` sur Linux, `ipconfig` sur Windows).
2. **Décider consciemment : activer, ou désactiver et documenter** — Ne jamais laisser IPv6 « actif par défaut, non géré » : soit on le déploie proprement, soit on le désactive explicitement avec une justification documentée.
3. **Choisir un mode de coexistence (dual-stack recommandé)** — Faire fonctionner IPv4 et IPv6 en parallèle sur les mêmes interfaces, le mode le plus simple et le plus robuste pour une infrastructure d'entreprise.
4. **Étendre le pare-feu à IPv6** — Un pare-feu configuré uniquement pour IPv4 laisse un service exposé sans filtrage s'il répond aussi en IPv6 (Partie III et XI).
5. **Étendre la supervision et les journaux** — S'assurer que les outils de supervision (Partie X) capturent aussi le trafic et les connexions IPv6.

Configuration : exemples de commandes

```
# Linux - afficher les adresses IPv6
ip -6 addr show

# Linux - table de routage IPv6
ip -6 route show

# Linux - désactiver IPv6 sur une interface (si stratégie de désactivation)
sysctl -w net.ipv6.conf.eth0.disable_ipv6=1

# Windows PowerShell - afficher la configuration IPv6
Get-NetIPAddress -AddressFamily IPv6

# Windows - désactiver IPv6 sur un adaptateur (si stratégie de désactivation)
Disable-NetAdapterBinding -Name "Ethernet" -ComponentID ms_tcpip6
```

| Administration courante

- Vérifier que la politique de pare-feu (Partie III) couvre IPv4 **et** IPv6 de façon symétrique, sur chaque serveur exposé
- Documenter le choix (dual-stack actif, ou IPv6 désactivé) dans la cartographie d'architecture (Partie I, Chapitre 3)
- Surveiller l'évolution du support IPv6 chez les fournisseurs cloud utilisés (Partie XII), de plus en plus souvent natif ou requis

| Bonnes pratiques

À appliquer systématiquement

- Prendre une décision explicite sur IPv6 (activer proprement en dual-stack, ou désactiver et documenter pourquoi), jamais le laisser dans un état non géré
- Si dual-stack est choisi, dupliquer systématiquement toute règle de pare-feu IPv4 vers son équivalent IPv6
- Utiliser des adresses ULA (fc00::/7) pour les communications strictement internes, à l'image des plages privées RFC 1918 en IPv4

Erreurs courantes

⚠ À éviter

- Durcir un pare-feu ou un service uniquement en IPv4 en pensant que « le réseau est en IPv4 », alors qu'IPv6 est actif par défaut sur les systèmes modernes
- Confondre lien-local (`fe80::`) et adresse routable : une adresse lien-local ne fonctionne que sur le segment local, jamais à travers un routeur
- Sous-estimer la surface d'attaque supplémentaire qu'introduit un dual-stack mal maîtrisé

Dépannage

Symptôme	Cause probable	Vérification
Connectivité IPv4 correcte mais IPv6 inaccessible depuis l'extérieur	Pare-feu bloquant en IPv6 alors qu'il autorise en IPv4	Comparer explicitement les deux jeux de règles
Un serveur répond différemment selon le client (IPv4 vs IPv6)	Service en écoute uniquement sur une des deux piles	Vérifier la configuration d'écoute du service (<code>0.0.0.0</code> vs <code>::</code>)

Recommandations de sécurité

Sécurité

IPv6 actif « par défaut mais non géré » est un des angles morts de sécurité les plus fréquents en entreprise : un attaquant scannant en IPv6 peut trouver des services non protégés par un pare-feu qui n'a été durci qu'en IPv4. Tout audit de durcissement (Partie XI) doit systématiquement couvrir les deux piles, ou documenter explicitement la désactivation complète d'IPv6 si c'est le choix retenu.

Cas pratique — Haitech Solutions

Cas pratique

Aucun projet du portefeuille actuel de Haitech Solutions (OTELA, ANTENN) n'expose de service directement sur IPv6 — tous sont hébergés derrière des plateformes (Railway, Vercel) ou des infrastructures qui gèrent cette couche en amont. Cela ne dispense pas d'un audit explicite lors du choix d'un futur hébergement on-premise ou VPS (comme envisagé pour le VPS mail de POSTA, toujours non provisionné) : vérifier dès l'installation si IPv6 est actif par défaut sur l'image système choisie, et appliquer la même politique de pare-feu qu'en IPv4 dès le premier jour plutôt que de le découvrir a posteriori lors d'un audit de sécurité.

Résumé du chapitre

- IPv6 offre un espace d'adressage sur 128 bits, avec des mécanismes propres (SLAAC, NDP, multicast à la place du broadcast).
- Le mode dual-stack (IPv4 + IPv6 en parallèle) est la stratégie de coexistence la plus robuste.
- Toute règle de pare-feu IPv4 doit avoir son équivalent IPv6 explicitement vérifié.

- IPv6 actif par défaut mais non géré est un angle mort de sécurité fréquent à auditer systématiquement.

Chapitre suivant : topologies réseau et câblage structuré.

PARTIE II · CHAPITRE 10

Topologies réseau et câblage structuré

Rôle des topologies réseau

La topologie décrit la façon dont les équipements réseau sont physiquement et logiquement reliés entre eux. Ce choix conditionne directement la résilience (une panne d'un équipement isole-t-elle une partie du réseau ?), la performance (combien de sauts entre deux points ?) et le coût (combien de câblage et d'équipements actifs sont nécessaires). Un administrateur système doit savoir reconnaître la topologie en place, en identifier les points de défaillance unique (SPOF, Partie I Chapitre 3), et choisir la bonne topologie pour un nouveau déploiement.

Fonctionnement : les topologies courantes

Topologie	Description	Résilience	Usage typique
Bus	Tous les équipements partagent un unique câble	Très faible (une coupure isole tout le segment)	Obsolète, historique uniquement

Topologie	Description	Résilience	Usage typique
Étoile	Chaque équipement relié individuellement à un switch central	Dépend du switch central (SPOF)	Standard en entreprise aujourd'hui
Étoile étendue (hiérarchique)	Plusieurs étoiles reliées à un switch cœur de réseau	Bonne si le cœur est redondé	Réseaux PME à grande entreprise
Maillée (mesh)	Chaque nœud relié à plusieurs autres	Excellente, coûteuse en câblage	Cœurs de réseau critiques, datacenters
Anneau	Chaque équipement relié à ses deux voisins en boucle	Moyenne (redondance native mais rupture=isolement partiel)	Réseaux opérateur, certains SAN

À savoir

La quasi-totalité des réseaux d'entreprise modernes suivent une architecture hiérarchique à trois niveaux : **cœur** (core, commutation à très haute performance entre blocs), **distribution** (agrégation et routage inter-VLAN), **accès** (access, où se connectent postes et périphériques). Cette hiérarchie facilite la croissance et l'isolement des pannes.

Prérequis à la conception ou à l'audit d'une topologie

- Un inventaire des bâtiments, étages et distances entre points de connexion
- Une estimation du nombre de prises réseau nécessaires par zone, avec marge de croissance
- La connaissance des normes de câblage applicables (voir 10.5)

Mise en place : méthode de conception

1. **Réaliser un relevé physique (site survey)** — Mesurer chaque distance, identifier les obstacles (murs porteurs, gaines existantes).
2. **Positionner le local technique / la salle serveur** — Central par rapport aux zones desservies, sécurisé, ventilé.
3. **Calculer les longueurs de câble avec marge** — Ajouter 15 à 20 % à chaque mesure réelle pour les coudes et le passage.
4. **Respecter la limite de 100 m par lien cuivre** — Norme TIA-568 : 90 m de câble horizontal maximum + 10 m de cordons de brassage.
5. **Prévoir la fibre optique pour les liaisons inter-bâtiments** — Au-delà de 100 m, ou pour un débit garanti supérieur au cuivre.
6. **Organiser et étiqueter le câblage dès la pose** — Voir méthode détaillée ci-dessous.

Configuration : normes de câblage structuré

Catégorie de câble	Débit garanti	Distance max	Usage recommandé
Cat5e	1 Gbit/s	100 m	Minimum acceptable, à éviter en neuf
Cat6	1 Gbit/s (10 Gbit/s à courte distance)	100 m (55 m pour 10G)	Standard actuel pour tout nouveau câblage
Cat6A	10 Gbit/s	100 m	Zones à fort besoin de débit (salle serveur)
Fibre OM3/OM4 (multimode)	10 à 40 Gbit/s	300-400 m	Liaisons inter-bâtiments, inter-racks
Fibre OS2 (monomode)	10 Gbit/s et plus	Plusieurs km	Longue distance, inter-sites

Organisation du rack et étiquetage

- Numéroté chaque câble aux deux extrémités dès sa pose, avec un format cohérent (ex. **A-1-BUR01-P1** pour Bâtiment A, étage 1, bureau 01, prise 1)
- Tenir un tableau de brassage à jour (panneau de brassage ↔ port switch ↔ prise murale)
- Regrouper les câbles par destination avec des serre-câbles réutilisables (velcro, jamais de collier plastique définitif qui empêche toute évolution)
- Séparer physiquement courants forts (alimentation 220V) et courants faibles (réseau), distance minimale de 20 cm

À appliquer systématiquement

Tester chaque câble après pose avec un testeur de continuité basique au minimum (huit voyants dans l'ordre), et documenter le résultat. Pour un lien critique (backbone, salle serveur), une certification complète (Fluke DSX) confirme le débit réellement supportable, pas seulement la continuité électrique.

Administration courante

- Mettre à jour le tableau de brassage à chaque ajout, déplacement ou retrait de câble
- Auditer périodiquement la cohérence entre le tableau déclaré et la réalité physique du rack
- Prévoir 20 à 30 % de ports libres sur chaque switch et chaque panneau de brassage pour l'évolution

Bonnes pratiques

À appliquer systématiquement

- Privilégier systématiquement une topologie en étoile hiérarchique pour tout nouveau déploiement d'entreprise
- Redonder le switch cœur de réseau dès que la criticité métier le justifie (Partie IX, haute disponibilité)
- Documenter le rayon de courbure minimal de la fibre optique (généralement 30 mm) : la plier au-delà l'endommage silencieusement, sans casse visible immédiate

Erreurs courantes

À éviter

- Dépasser les 100 m de câble cuivre horizontal, provoquant des erreurs intermittentes difficiles à diagnostiquer plutôt qu'une panne franche
- Mélanger courants forts et courants faibles dans la même goulotte, source d'interférences électromagnétiques
- Négliger l'étiquetage « au moment de la pose », pariant sur une documentation a posteriori qui n'arrive jamais (voir Partie I, Chapitre 4)
- Sous-dimensionner le nombre de prises par poste de travail (une seule prise pour PC + téléphone IP + éventuel second écran réseau)

Dépannage

Symptôme	Cause probable	Vérification
Erreurs intermittentes sur un lien, débit	Câble trop long (> 100 m) ou de catégorie	Mesurer la longueur réelle, vérifier la

Symptôme	Cause probable	Vérification
anormalement bas	insuffisante	catégorie
Un segment entier de bâtiment tombe en même temps	Panne du switch de distribution desservant ce segment (SPOF)	Vérifier la redondance prévue (Partie IX)
Perte de signal sur une liaison fibre inter-bâtiments	Connecteur sale ou câble plié au-delà du rayon minimal	Nettoyer les connecteurs, inspecter le tracé physique

Recommandations de sécurité

Sécurité

Le local technique et les racks doivent être physiquement sécurisés (accès restreint, si possible tracé) : un accès physique non contrôlé à un switch ou à un panneau de brassage permet de contourner n'importe quelle protection logique (VLAN, pare-feu). La sécurité physique (Partie XI) est une couche de défense à part entière, souvent négligée au profit de la seule sécurité logique.

Cas pratique — Haitech Solutions

Cas pratique

Le manuel de formation [livrables/formations/manuel-reseau-entreprise/](#) et le projet [livrables/reseau/](#) (générateur de devis et de plans réseau, utilisé pour des missions clients réelles) documentent déjà la méthode complète de site survey, de calcul de longueurs de câble avec marge de 20 %, et d'organisation de rack décrite dans ce chapitre. Cette même méthode, éprouvée sur des missions de conseil réseau antérieures, est directement applicable à toute extension physique de l'infrastructure de Haitech Solutions.

Résumé du chapitre

- La topologie en étoile hiérarchique (accès, distribution, cœur) est le standard des réseaux d'entreprise modernes.
- La limite de 100 m s'applique à tout lien cuivre horizontal ; au-delà, la fibre optique est nécessaire.
- L'étiquetage et le tableau de brassage doivent être tenus à jour au moment de la pose, pas a posteriori.
- La sécurité physique du câblage et des racks est une couche de défense à part entière.

Chapitre suivant : VLAN et segmentation logique du réseau.

VLAN et segmentation logique

Rôle des VLAN

Un VLAN (Virtual LAN) segmente logiquement un réseau physique unique en plusieurs domaines de diffusion (broadcast) distincts, sans câblage supplémentaire. C'est l'outil de segmentation le plus utilisé en entreprise : il isole le trafic par fonction (administration, serveurs, invités, caméras...), réduit la taille de chaque domaine de broadcast (donc améliore la performance) et constitue la première ligne de segmentation de sécurité, complémentaire au pare-feu (Partie III).

Fonctionnement : ports access et ports trunk

Type de port	Comportement	Usage
Access	Appartient à un seul VLAN ; les trames ne portent aucune étiquette (untagged)	Connexion d'un poste, d'une imprimante, d'une caméra
Trunk	Transporte plusieurs VLAN simultanément, chaque trame étiquetée (802.1Q tagged)	Liaison entre switches, ou switch vers routeur/pare-feu

Le standard **802.1Q** insère une étiquette de 4 octets dans la trame Ethernet, contenant l'identifiant de VLAN (VLAN ID, de 1 à 4094). Un port trunk peut restreindre la liste des VLAN autorisés à transiter (« allowed vlan »), une pratique de sécurité recommandée plutôt que d'autoriser tous les VLAN par défaut.

À savoir

La communication entre deux VLAN différents nécessite obligatoirement un équipement de couche 3 (routeur, ou switch « L3 » capable de router) : deux hôtes sur deux VLAN distincts, même connectés au même switch physique, ne peuvent pas communiquer directement sans passer par ce routage inter-VLAN.

Prérequis

- Un plan d'adressage IP déjà défini par fonction (Chapitre 8), chaque VLAN correspondant en général à un sous-réseau IP dédié
- Des switches manageables supportant le 802.1Q (la quasi-totalité des switches professionnels actuels)
- Une décision claire sur le VLAN natif (untagged par défaut sur les ports trunk), à sécuriser (voir recommandations de sécurité)

Mise en place d'une segmentation VLAN

1. **Définir la liste des VLAN nécessaires** — À partir du plan d'adressage déjà établi (Chapitre 8).
2. **Créer les VLAN sur chaque switch manageable** — Numéro et nom cohérents sur l'ensemble de l'infrastructure.
3. **Configurer les ports access** — Un VLAN par port de périphérique final.
4. **Configurer les ports trunk** — Entre switches, et vers le routeur/pare-feu assurant le routage inter-VLAN.
5. **Configurer les interfaces virtuelles (SVI) sur le routeur ou switch L3** — Une passerelle par VLAN.
6. **Appliquer les règles de filtrage inter-VLAN** — Via ACL ou règles de pare-feu (Partie III), selon la politique de sécurité voulue.

Configuration : exemples de commandes

```
# Cisco IOS – création des VLAN
vlan 10
  name ADMINISTRATION
vlan 40
  name CAMERAS
vlan 99
  name INVITES
exit

# Cisco IOS – port access (poste de travail)
interface GigabitEthernet0/1
  switchport mode access
  switchport access vlan 10
  spanning-tree portfast
  no shutdown

# Cisco IOS – port trunk (vers un autre switch ou le routeur)
interface GigabitEthernet0/24
  switchport trunk encapsulation dot1q
  switchport mode trunk
  switchport trunk allowed vlan 10,20,40,99
  no shutdown

# MikroTik RouterOS – VLAN sur bridge
/interface bridge add name=bridge-lan vlan-filtering=yes
/interface vlan add name=vlan10 vlan-id=10 interface=ether2
/ip address add address=192.168.10.1/24 interface=vlan10

# Linux – création d'une interface VLAN taguée
ip link add link eth0 name eth0.10 type vlan id 10
ip addr add 192.168.10.5/24 dev eth0.10
ip link set eth0.10 up
```

Administration courante

- Vérifier régulièrement l'état des ports trunk (`show interfaces trunk` sur Cisco) et l'absence de VLAN non autorisé qui y transiterait

- Auditer la liste des VLAN configurés contre le plan d'adressage documenté (Partie I, Chapitre 3), pour détecter les dérives
- Surveiller les tempêtes de broadcast, souvent révélatrices d'une boucle réseau (voir Spanning Tree Protocol ci-dessous)

Le Spanning Tree Protocol (STP) : prévenir les boucles

Le STP empêche les boucles réseau qui surviendraient si deux switches étaient reliés par plusieurs chemins redondants (une configuration pourtant recommandée pour la résilience, Partie IX). Sans STP, une boucle provoque une tempête de broadcast qui sature le réseau en quelques secondes. Le PortFast (activé uniquement sur les ports access connectés à un poste final, jamais sur un port trunk) accélère la mise en service du port en évitant les états intermédiaires du STP inutiles pour un simple poste de travail.

Bonnes pratiques

💡 À appliquer systématiquement

- Restreindre systématiquement la liste des VLAN autorisés sur chaque port trunk au strict nécessaire (`switchport trunk allowed vlan`)
- Changer le VLAN natif par défaut (VLAN 1) vers un VLAN dédié inutilisé, jamais laissé à sa valeur d'usine
- Nommer les VLAN de façon explicite et cohérente sur toute l'infrastructure (ADMINISTRATION, SERVEURS, INVITES...)
- Activer PortFast uniquement sur les ports access, jamais sur les ports trunk

Erreurs courantes

⚠ À éviter

- Laisser tous les VLAN autorisés par défaut sur un port trunk (« allowed vlan all »), élargissant inutilement la surface d'attaque en cas de compromission d'un switch
- Oublier de configurer le routage inter-VLAN alors qu'une communication entre deux VLAN est attendue
- Créer un VLAN uniquement sur certains switches de l'infrastructure, provoquant des incohérences difficiles à diagnostiquer
- Négliger le VLAN natif, souvent oublié dans l'étiquetage 802.1Q et exploitable pour une attaque de VLAN hopping (Partie XI)

Dépannage

Symptôme	Cause probable	Vérification
Un poste ne reçoit aucune adresse IP	Port mal configuré, mauvais VLAN access	Vérifier <code>show interfaces status</code> , la configuration du port
Deux VLAN qui devraient communiquer ne le peuvent pas	Absence de routage inter-VLAN ou règle de pare-feu bloquante	Vérifier les interfaces SVI et les règles de filtrage (Partie III)
Ralentissements généralisés, tempête de broadcast	Boucle réseau, STP mal configuré ou désactivé	Vérifier <code>show spanning-tree</code> , rechercher un câblage en boucle

Recommandations de sécurité

Sécurité

Le VLAN hopping est une technique d'attaque qui exploite un VLAN natif mal sécurisé ou un port mal configuré en mode trunk automatique (DTP sur Cisco) pour accéder à un VLAN normalement inaccessible depuis un simple poste utilisateur. Désactiver la négociation automatique de trunk sur les ports access (`switchport nonegotiate`), changer le VLAN natif par défaut, et restreindre strictement les VLAN autorisés par trunk sont les trois mesures de base contre cette classe d'attaque.

Cas pratique — Haitech Solutions

Cas pratique

Le plan d'adressage à huit VLAN documenté dans `livrables/reseau/` (Administration, Comptabilité, Direction, Caméras, Wi-Fi employés, Serveurs, Téléphonie IP, Invités) illustre exactement la méthode de ce chapitre appliquée à une mission client réelle : chaque fonction métier reçoit son propre VLAN et son propre sous-réseau, avec un VLAN Invités explicitement isolé du reste par des règles de pare-feu dédiées (Partie III). C'est le même schéma que Haitech Solutions peut répliquer pour son propre réseau interne, en adaptant simplement la liste des fonctions aux besoins réels de l'organisation.

Résumé du chapitre

- Un VLAN segmente logiquement un réseau physique unique en domaines de diffusion distincts, sans câblage supplémentaire.
- Les ports access portent un seul VLAN non étiqueté ; les ports trunk transportent plusieurs VLAN étiquetés (802.1Q).

- La communication inter-VLAN exige un équipement de couche 3 (routeur ou switch L3).
- Restreindre les VLAN autorisés par trunk et sécuriser le VLAN natif sont deux mesures de sécurité de base.

Chapitre suivant : le routage, statique et dynamique.

PARTIE II · CHAPITRE 12

Le routage : statique et dynamique

Rôle du routage

Le routage détermine par quel chemin un paquet IP doit transiter pour atteindre un réseau qui n'est pas directement connecté à l'équipement émetteur. Chaque routeur (ou switch L3) consulte sa table de routage pour chaque paquet et choisit la route la plus spécifique disponible vers la destination. Sans routage correctement configuré, deux VLAN ou deux sites ne peuvent tout simplement pas communiquer, quelle que soit la qualité du câblage ou de la segmentation.

Fonctionnement : route statique contre routage dynamique

Approche	Principe	Avantages	Inconvénients
Routage statique	Routes configurées manuellement, une par une	Simple, prévisible, pas de trafic de protocole	Ne s'adapte pas automatiquement à une panne de lien ; charge de maintenance manuelle qui croît avec le nombre de sites

Approche	Principe	Avantages	Inconvénients
Routage dynamique	Les routeurs échangent automatiquement leurs routes via un protocole	S'adapte automatiquement aux pannes, scalable	Plus complexe à concevoir et sécuriser

Protocoles de routage dynamique courants

Protocole	Type	Portée typique	Métrique
RIP	Vecteur de distance	Obsolète, petits réseaux historiques	Nombre de sauts (max 15)
OSPF	État de liens	Réseau d'entreprise interne (IGP)	Coût basé sur la bande passante
EIGRP	Hybride (Cisco propriétaire)	Réseau d'entreprise interne	Bande passante, délai, fiabilité
BGP	Vecteur de chemin	Internet, interconnexion entre organisations (EGP)	Attributs de chemin (longueur AS, préférences)

À savoir

OSPF (Open Shortest Path First) est le protocole de routage dynamique interne (IGP) le plus répandu en entreprise : ouvert (non propriétaire), converge rapidement après une panne, et s'organise en zones (areas) pour limiter la charge de calcul sur les grands réseaux. BGP, à l'inverse, gère le routage **entre** organisations (Internet lui-même) et n'a en pratique sa place dans une PME que pour un usage multi-hébergeur avancé (multihoming).

Prérequis

- Une table d'adressage IP déjà définie par sous-réseau (Chapitre 8)
- Pour le routage dynamique : des équipements compatibles et une conception des zones/aires cohérente
- Une compréhension de la métrique et de la distance administrative, qui déterminent quelle route est préférée en cas de choix multiple

Mise en place du routage inter-VLAN et inter-sites

1. **Router-on-a-stick ou switch L3** — Pour le routage inter-VLAN local, soit une interface unique en trunk vers un routeur (« router-on-a-stick »), soit un switch capable de router nativement (L3), plus performant pour un trafic important.
2. **Définir la route par défaut** — Chaque routeur non-cœur a besoin d'une route par défaut (`0.0.0.0/0`) pointant vers la passerelle suivante, généralement vers Internet.
3. **Configurer les routes statiques nécessaires** — Pour les liaisons simples (deux sites, un seul chemin possible), le statique suffit et reste plus simple à auditer.
4. **Déployer un protocole dynamique si la topologie le justifie** — Plusieurs chemins redondants entre sites, ou plus de trois à quatre routeurs internes à interconnecter.
5. **Documenter chaque route** dans la cartographie d'architecture (Partie I, Chapitre 3).

Configuration : exemples de commandes

```
# Cisco IOS – route statique
ip route 192.168.40.0 255.255.255.0 10.0.0.2

# Cisco IOS – route par défaut
ip route 0.0.0.0 0.0.0.0 203.0.113.1

# Cisco IOS – activation d'OSPF, zone 0
router ospf 1
 network 192.168.10.0 0.0.0.255 area 0
 network 192.168.20.0 0.0.0.255 area 0

# Linux – route statique
ip route add 192.168.40.0/24 via 10.0.0.2

# Linux – route par défaut
ip route add default via 203.0.113.1

# Windows PowerShell – route statique persistante
New-NetRoute -DestinationPrefix "192.168.40.0/24" -NextHop 10.0.0.2 -Inter
```

Administration courante

- Vérifier périodiquement la table de routage active (`show ip route` , `ip route show`) contre la documentation attendue
- Surveiller la convergence après un test de coupure planifiée d'un lien redondant (partie intégrante d'un exercice de continuité, Partie XII)
- Auditer les routes statiques résiduelles après tout changement de topologie, source fréquente de routes mortes non nettoyées

Distance administrative : quelle route gagne en cas de conflit

Source	Distance administrative (Cisco, par défaut)
Réseau directement connecté	0

Source	Distance administrative (Cisco, par défaut)
Route statique	1
eBGP	20
OSPF	110
RIP	120
iBGP	200

Plus la distance administrative est faible, plus la route est préférée. Une route statique (distance 1) l’emporte donc toujours sur une route apprise dynamiquement par OSPF (110) vers la même destination, sauf configuration explicite contraire — un point de vigilance lors du dépannage d’un comportement de routage inattendu.

| Bonnes pratiques

À appliquer systématiquement

- Documenter chaque route statique avec sa justification (pourquoi cette route existe, quel lien elle sert)
- Ne déployer un protocole dynamique que si la complexité de la topologie le justifie réellement
- Sécuriser l’authentification des échanges de routage dynamique (MD5 sur OSPF a minima) pour éviter l’injection de fausses routes

Erreurs courantes

⚠ À éviter

- Laisser des routes statiques obsolètes après un changement de topologie, provoquant un routage silencieusement incorrect
- Configurer un protocole dynamique sans authentification, exposant le réseau à une injection de routes malveillantes
- Oublier la route par défaut sur un routeur non-cœur, le rendant incapable de joindre Internet ou le reste du réseau

Dépannage

Symptôme	Cause probable	Vérification
Un réseau distant est injoignable	Route manquante ou mal configurée	<code>traceroute</code> vers la destination, comparer avec la table de routage attendue
Le trafic emprunte un chemin sous-optimal	Distance administrative ou métrique mal comprise	Vérifier <code>show ip route</code> et la métrique de chaque route candidate
Convergence lente après une panne de lien	Protocole de routage dynamique mal réglé (timers par défaut) ou absence de routage dynamique	Vérifier les timers OSPF, envisager un protocole dynamique si redondance critique

Recommandations de sécurité

Sécurité

Un protocole de routage dynamique non authentifié permet à un attaquant présent sur le réseau d'injecter de fausses routes et de détourner le trafic (attaque de type « route injection »). Activer systématiquement l'authentification MD5 (au minimum) sur les échanges OSPF, et filtrer strictement les interfaces sur lesquelles le protocole de routage est actif — jamais sur un port exposé à des équipements non maîtrisés (VLAN invités, par exemple).

Cas pratique — Haitech Solutions

Cas pratique

OTELA (multi-établissements) et ANTENN illustrent, côté applicatif plutôt que réseau pur, le même principe de routage explicite que ce chapitre : `resolveEtablissement` route chaque requête vers les données du bon établissement selon le token d'authentification, jamais selon un paramètre client modifiable. Le parallèle est direct avec une route statique bien documentée plutôt qu'une route implicite non maîtrisée : dans les deux cas, la décision de « où envoyer ceci » doit reposer sur une source de vérité fiable et vérifiée, jamais sur une donnée que l'émetteur pourrait falsifier.

Résumé du chapitre

- Le routage statique convainc par sa simplicité pour des topologies limitées ; le routage dynamique (OSPF en interne) s'impose dès que la redondance et l'échelle le justifient.
- La distance administrative détermine quelle route l'emporte en cas de conflit entre plusieurs sources.

- Toute route statique doit être documentée et nettoyée après un changement de topologie.
- L'authentification des échanges de routage dynamique est une mesure de sécurité de base, souvent omise.

Chapitre suivant : NAT et PAT, la translation d'adresses.

PARTIE II · CHAPITRE 13

NAT et PAT : translation d'adresses

Rôle du NAT

Le NAT (Network Address Translation) traduit des adresses IP privées (RFC 1918, Chapitre 8) en une ou plusieurs adresses IP publiques, permettant à un réseau interne entier de partager un accès Internet via une poignée d'adresses publiques, voire une seule. Au-delà de l'économie d'adresses IPv4 publiques (sa motivation historique), le NAT constitue de fait une barrière de sécurité de base : un hôte interne en adressage privé n'est jamais directement joignable depuis Internet sans une règle de translation explicite.

Fonctionnement : les types de NAT

Type	Principe	Usage typique
NAT statique (1:1)	Une adresse privée toujours traduite vers la même adresse publique	Serveur devant garder une adresse publique fixe et prévisible
NAT dynamique	Un pool d'adresses publiques attribuées dynamiquement aux hôtes internes	De moins en moins utilisé, remplacé par le PAT

Type	Principe	Usage typique
PAT (NAT Overload)	Plusieurs adresses privées partagent une seule adresse publique, distinguées par le port source	Standard en sortie Internet pour la quasi-totalité des réseaux d'entreprise
Port forwarding (DNAT)	Un port spécifique de l'adresse publique est redirigé vers une adresse et un port internes	Exposer un service interne précis (serveur web, VPN) sans NAT statique complet

À savoir

Le PAT (Port Address Translation), souvent appelé simplement « NAT » dans le langage courant, réécrit à la fois l'adresse IP source et le port source de chaque connexion sortante, en conservant une table de correspondance temporaire. C'est ce mécanisme qui permet à des centaines de postes internes de partager une unique adresse IP publique simultanément.

Prérequis

- Un plan d'adressage privé déjà défini (Chapitre 8)
- Une ou plusieurs adresses IP publiques allouées par le fournisseur d'accès
- Une décision claire sur les services devant être exposés depuis Internet (et donc nécessitant du port forwarding)

Mise en place du NAT/PAT

1. **Configurer le PAT en sortie** — Toutes les adresses privées internes traduites vers l'adresse IP publique WAN à la sortie du routeur/pare-feu.
2. **Identifier les services à exposer** — Lister précisément quel service interne doit être joignable depuis Internet, et sur quel port.

3. **Configurer le port forwarding (DNAT) service par service** — Jamais une exposition large et non ciblée.
4. **Restreindre par IP source si possible** — Limiter le port forwarding à des IP sources connues quand le service ne nécessite pas un accès public universel.
5. **Documenter chaque règle** avec sa justification métier, dans le registre des changements (Partie X).

Configuration : exemples de commandes

```
# MikroTik RouterOS – PAT (masquerade) pour la sortie Internet
/ip firewall nat add chain=srcnat out-interface=ether1 action=masquerade

# MikroTik RouterOS – port forwarding (accès distant à un serveur interne)
/ip firewall nat add chain=dstnat protocol=tcp dst-port=8080 \
    action=dst-nat to-addresses=192.168.20.10 to-ports=80

# Linux iptables – PAT via masquerade
iptables -t nat -A POSTROUTING -o eth0 -j MASQUERADE

# Linux iptables – port forwarding
iptables -t nat -A PREROUTING -i eth0 -p tcp --dport 8080 \
    -j DNAT --to-destination 192.168.20.10:80

# Cisco IOS – PAT (NAT overload)
ip nat inside source list 1 interface GigabitEthernet0/0 overload
access-list 1 permit 192.168.0.0 0.0.255.255
```

Administration courante

- Auditer périodiquement la liste des règles de port forwarding actives contre la liste des services réellement nécessaires (Partie I, Chapitre 5 — inventaire)
- Surveiller la table de translation NAT sur les pare-feu à fort trafic, une saturation de cette table peut provoquer des coupures de connexion
- Retirer systématiquement toute règle de port forwarding devenue inutile lors du décommissionnement d'un service

Bonnes pratiques

À appliquer systématiquement

- Restreindre chaque règle de port forwarding au strict service nécessaire, jamais une plage large « au cas où »
- Documenter la justification métier de chaque règle de NAT, en particulier le port forwarding, qui expose directement un service interne
- Préférer un VPN (Partie III) à un port forwarding direct pour l'administration à distance de serveurs sensibles
- Utiliser le NAT statique (1:1) uniquement pour les cas qui l'exigent réellement (adresse publique fixe requise), pas par défaut

Erreurs courantes

À éviter

- Exposer un service d'administration (RDP, SSH, interface de gestion) directement via port forwarding sans VPN ni restriction d'IP source
- Accumuler des règles de port forwarding non documentées au fil du temps, sans jamais les auditer ni les nettoyer
- Confondre NAT et sécurité : le NAT masque l'adressage interne mais ne remplace en aucun cas un pare-feu avec inspection de trafic (Partie III)
- Oublier qu'un serveur derrière NAT ne peut pas recevoir de connexion entrante non sollicitée sans règle de translation explicite, cause fréquente de « ça marche en sortie mais pas en entrée »

Dépannage

Symptôme	Cause probable	Vérification
Les postes internes accèdent à Internet mais un service externe ne peut pas joindre un serveur interne	Absence de règle de port forwarding (DNAT)	Vérifier les règles NAT dstnat/DNAT sur le pare-feu
Un service exposé publiquement reste inaccessible malgré une règle de port forwarding correcte	Pare-feu bloquant le trafic après translation, ou service en écoute sur une autre interface	Vérifier l'ordre des règles pare-feu et l'interface d'écoute du service
Des connexions se coupent de façon aléatoire sous forte charge	Table de translation NAT saturée	Vérifier les limites de connexions simultanées du pare-feu, envisager un équipement plus dimensionné

Recommandations de sécurité

Sécurité

Le NAT n'est pas un mécanisme de sécurité en soi, même s'il en a l'effet secondaire (un hôte interne n'est pas directement adressable depuis Internet sans règle explicite). Toute règle de port forwarding doit être traitée avec la même rigueur qu'une règle de pare-feu ouvrant un accès : justification documentée, restriction d'IP source quand c'est possible, et revue périodique. Un service d'administration exposé par port forwarding sans authentification forte (Partie XI, MFA) reste une des causes les plus fréquentes de compromission initiale d'un réseau d'entreprise.

Cas pratique — Haitech Solutions

✦ Cas pratique

Le manuel de formation réseau documente une règle de port forwarding vers un NVR de vidéosurveillance comme exemple type d'exposition ciblée (port 8080 public redirigé vers le port 80 du NVR interne). Ce même principe de restriction stricte — n'exposer que le strict service nécessaire, jamais un accès large — s'applique directement à toute future exposition de services internes de Haitech Solutions, qu'il s'agisse d'un accès distant à une caméra de site ou d'un accès administratif ponctuel, toujours à privilégier via VPN (Chapitre suivant, Partie III) plutôt que par port forwarding direct.

Résumé du chapitre

- Le PAT (NAT overload) permet à un réseau interne entier de partager une seule adresse IP publique.
- Le port forwarding (DNAT) expose un service interne précis, et doit toujours être restreint au strict nécessaire.
- Le NAT masque l'adressage interne mais ne remplace jamais un pare-feu avec inspection de trafic.
- Un service d'administration ne devrait jamais être exposé par port forwarding direct sans VPN ni authentification forte.

Ceci conclut la Partie II. Partie suivante : services réseau essentiels (DNS, DHCP, pare-feu, proxy, VPN, répartition de charge).

Services réseau essentiels

La Partie II a posé les fondations : adressage, segmentation, routage. Cette partie couvre les services qui rendent un réseau réellement utilisable au quotidien : la résolution de noms (DNS), l'attribution automatique d'adresses (DHCP), le filtrage de trafic (pare-feu), l'intermédiation de flux (proxy et reverse proxy), l'accès distant sécurisé (VPN) et la répartition de charge entre plusieurs serveurs (load balancing).

Ces six chapitres forment l'ossature de services que tout administrateur système configure et dépanne en continu — et sur lesquels reposent directement les Parties IV (identité) et XI (cybersécurité).

DNS : le système de résolution de noms

Rôle du DNS

Le DNS (Domain Name System) traduit des noms de domaine lisibles par des humains (`otela.ht`) en adresses IP exploitables par les machines. C'est un service critique et souvent invisible : sa panne donne l'impression que « tout Internet est cassé », alors que la connectivité IP brute fonctionne parfaitement. Pour un administrateur système, le DNS est aussi un service interne indispensable : résolution des noms de machines sur le réseau local, intégration avec Active Directory (Partie IV), et souvent première ligne de détection d'une compromission (requêtes DNS vers des domaines malveillants).

Fonctionnement : la hiérarchie DNS

Niveau	Exemple	Rôle
Racine	.	Point d'entrée, connaît les serveurs de chaque TLD
TLD (domaine de premier niveau)	.ht , .com , .org	Connaît les serveurs faisant autorité pour chaque domaine enregistré
Domaine faisant autorité	otela.ht	Détient les enregistrements réels du domaine
Sous-domaine	app.otela.ht	Peut être délégué à un autre serveur faisant

Niveau	Exemple	Rôle
		autorité

Types d'enregistrements courants

Type	Rôle	Exemple
A	Nom vers adresse IPv4	app.otela.ht → 203.0.113.10
AAAA	Nom vers adresse IPv6	app.otela.ht → 2001:db8::10
CNAME	Alias vers un autre nom	www.otela.ht → otela.ht
MX	Serveur de messagerie du domaine, avec priorité	otela.ht → mail.otela.ht (priorité 10)
TXT	Texte libre, souvent utilisé pour la validation (SPF, DKIM)	v=spf1 include:_spf.google.com ~all
NS	Serveurs faisant autorité pour le domaine	otela.ht → ns1.hebergeur.ht
PTR	Résolution inverse, IP vers nom	10.113.0.203.in-addr.arpa → app.otela.ht
SRV	Localisation d'un service (port et hôte)	Utilisé notamment par Active Directory (Partie IV)

À savoir

La résolution DNS est massivement mise en cache à chaque étape (résolveur du poste client, résolveur local de l'entreprise, résolveur du fournisseur d'accès) pour limiter la charge sur les serveurs faisant autorité. Le TTL (Time To Live) de chaque enregistrement détermine sa durée de cache : un TTL bas (300 s) permet une propagation rapide des changements mais augmente la charge de requêtes ; un TTL élevé (86400 s) réduit la charge mais ralentit la propagation d'un changement.

Prérequis

- Un plan d'adressage déjà en place (Chapitre 8), pour associer noms et IP de façon cohérente
- Une décision sur l'hébergement du DNS interne : intégré à Active Directory (Partie IV), ou serveur DNS dédié (BIND, Windows DNS, dnsmasq)
- Une convention de nommage interne (par exemple `serveur.interne.entreprise.local`)

Mise en place d'un service DNS interne

1. **Choisir le serveur DNS** — Windows DNS (si Active Directory déjà déployé), BIND9 (Linux, référence historique), ou Unbound/dnsmasq pour un usage plus léger.
2. **Configurer les zones** — Une zone directe (nom → IP) et, recommandé, une zone inverse (IP → nom) pour le diagnostic.
3. **Créer les enregistrements des serveurs internes critiques** — Chaque serveur avec un nom stable, jamais uniquement une IP mémorisée.
4. **Configurer la redirection (forwarding) vers des résolveurs externes** — Pour les requêtes hors du domaine interne (Internet public).
5. **Sécuriser les transferts de zone** — Restreindre quels serveurs peuvent répliquer la zone (voir sécurité ci-dessous).

Configuration : exemples de commandes

```
# Linux – interroger un enregistrement DNS
dig otela.ht A
dig otela.ht MX
nslookup otela.ht

# Linux – configuration BIND9, extrait de zone
$TTL 3600
@ IN SOA ns1.otela.ht. admin.otela.ht. (2026072301 3600 900 604800 3600)
@ IN NS ns1.otela.ht.
app IN A 203.0.113.10
mail IN A 203.0.113.20
@ IN MX 10 mail.otela.ht.

# Windows PowerShell – interroger le DNS
Resolve-DnsName otela.ht -Type A

# Windows Server – créer un enregistrement A via DNS Manager en CLI
Add-DnsServerResourceRecordA -Name "app" -ZoneName "otela.local" -IPv4Addr 203.0.113.10

# Windows – vider le cache DNS local
ipconfig /flushdns
```

Administration courante

- Surveiller les journaux de requêtes DNS pour détecter des domaines anormaux (indicateur précoce de compromission, Partie XI)
- Auditer périodiquement les enregistrements DNS publics contre l'inventaire réel des services exposés
- Vérifier la cohérence entre zone directe et zone inverse après chaque changement

Bonnes pratiques

À appliquer systématiquement

- Toujours désigner un serveur par son nom DNS dans la documentation et la configuration applicative, jamais par IP brute mémorisée
- Ajuster le TTL en fonction du contexte : abaisser temporairement le TTL avant une migration planifiée, pour accélérer la bascule
- Configurer au minimum deux serveurs DNS internes redondants (Partie IX, haute disponibilité)
- Mettre en place SPF, DKIM et DMARC (enregistrements TXT) pour tout domaine envoyant des emails, réduisant le risque d'usurpation (Partie XI)

Erreurs courantes

À éviter

- Laisser les transferts de zone ouverts à n'importe quel serveur (AXFR non restreint), exposant la totalité de la structure réseau interne à un attaquant
- Oublier de mettre à jour un enregistrement DNS après la migration d'un serveur, provoquant des pannes intermittentes selon le cache client
- Configurer un TTL très bas en permanence sans raison, augmentant inutilement la charge sur les serveurs faisant autorité
- Confondre propagation DNS et erreur de configuration : un changement DNS peut mettre jusqu'à la valeur du TTL précédent à se propager partout, ce n'est pas nécessairement un bug

Dépannage

Symptôme	Cause probable	Vérification
Le nom ne résout pas du tout	Enregistrement absent ou zone mal configurée	<code>dig</code> directement contre le serveur faisant autorité
La résolution renvoie une ancienne adresse IP	Cache local ou intermédiaire encore valide (TTL)	<code>ipconfig /flushdns</code> , attendre l'expiration du TTL
La résolution fonctionne en interne mais pas depuis Internet	Zone publique non mise à jour, ou split-DNS mal configuré	Vérifier séparément le DNS interne et le DNS public faisant autorité

Recommandations de sécurité

Sécurité

Restreindre les transferts de zone (AXFR) aux seuls serveurs secondaires légitimes est une mesure de sécurité de base trop souvent négligée. Envisager DNSSEC pour signer cryptographiquement les enregistrements d'un domaine public sensible, contre les attaques d'empoisonnement de cache. En interne, surveiller les requêtes DNS sortantes reste l'un des moyens les plus efficaces de détecter un poste compromis communiquant avec une infrastructure de commande et contrôle (Partie XI, SIEM).

Cas pratique — Haitech Solutions

✦ Cas pratique

POSTA (plateforme de mail personnalisé) réalise une vérification DNS réelle et complète (MX, SPF, DKIM, DMARC) avant d'autoriser l'activation d'un domaine client — un domaine n'est éligible au service mail qu'une fois ces quatre enregistrements confirmés par requête DNS effective, pas simplement déclarés par le client. C'est une application directe et rigoureuse des bonnes pratiques de ce chapitre : ne jamais faire confiance à une configuration DNS annoncée sans la vérifier par une requête réelle, un principe transposable à tout audit d'infrastructure de Haitech Solutions.

Résumé du chapitre

- Le DNS traduit les noms de domaine en adresses IP via une hiérarchie de serveurs faisant autorité.
- Le TTL détermine la durée de mise en cache de chaque enregistrement, à ajuster selon le contexte (migration à venir ou stabilité).
- Restreindre les transferts de zone et surveiller les requêtes sortantes sont deux mesures de sécurité de base.
- SPF, DKIM et DMARC sont indispensables pour tout domaine envoyant des emails légitimement.

Chapitre suivant : DHCP, l'attribution automatique d'adresses IP.

DHCP : attribution automatique d'adresses

Rôle du DHCP

Le DHCP (Dynamic Host Configuration Protocol) attribue automatiquement une adresse IP et les paramètres réseau associés (passerelle, DNS, masque) à chaque équipement qui rejoint le réseau, sans intervention manuelle. Sans DHCP, chaque poste, imprimante ou téléphone IP devrait être configuré manuellement en adresse statique — viable pour quelques serveurs, ingérable au-delà de quelques dizaines de postes.

Fonctionnement : le processus DORA

L'attribution DHCP suit un échange en quatre étapes, connu sous l'acronyme DORA :

1. **Discover** — Le client diffuse une requête de découverte (broadcast) sur le réseau local
2. **Offer** — Un ou plusieurs serveurs DHCP répondent avec une proposition d'adresse
3. **Request** — Le client demande formellement l'adresse proposée (accepte une offre parmi plusieurs)
4. **Acknowledge** — Le serveur confirme l'attribution et transmet les paramètres complets

À savoir

Le DHCP fonctionne nativement par diffusion (broadcast), limitée à un seul segment réseau (VLAN). Pour qu'un serveur DHCP centralisé serve plusieurs VLAN, chaque routeur/switch L3 doit relayer les requêtes via un agent relais DHCP (« IP helper » chez Cisco), qui transforme la diffusion locale en requête unicast vers le serveur DHCP distant.

Prérequis

- Un plan d'adressage déjà défini avec une plage DHCP clairement délimitée par VLAN (Chapitre 8)
- Une décision sur l'emplacement du service : intégré à un routeur/pare-feu, serveur Windows (rôle DHCP), ou serveur Linux dédié (`isc-dhcp-server` , `kea`)
- Une politique claire sur les réservations d'adresses (équipements devant toujours recevoir la même IP via DHCP)

Mise en place d'un service DHCP

1. **Définir l'étendue (scope) par VLAN** — Plage d'adresses à distribuer, en dehors des adresses statiques réservées (Chapitre 8).
2. **Configurer les options DHCP** — Passerelle par défaut, serveurs DNS, durée du bail (lease time).
3. **Configurer les réservations** — Association adresse MAC ↔ IP fixe, pour les équipements nécessitant une IP stable sans passer par une configuration statique manuelle.
4. **Configurer le relais DHCP** — Sur chaque routeur/switch L3 desservant un VLAN dont le serveur DHCP n'est pas local.
5. **Prévoir la redondance** — Deux serveurs DHCP avec un découpage de la plage (règle des 80/20, voir ci-dessous) ou un mécanisme de failover natif.

Configuration : exemples de commandes

```
# Linux isc-dhcp-server – extrait de configuration
subnet 192.168.10.0 netmask 255.255.255.0 {
    range 192.168.10.50 192.168.10.200;
    option routers 192.168.10.1;
    option domain-name-servers 192.168.10.1;
    default-lease-time 86400;
    max-lease-time 172800;
}

# Linux isc-dhcp-server – réservation par adresse MAC
host serveur-impression {
    hardware ethernet AA:BB:CC:DD:EE:FF;
    fixed-address 192.168.10.5;
}

# Cisco IOS – relais DHCP (ip helper-address) sur l'interface VLAN
interface vlan 30
ip helper-address 192.168.20.10

# Windows Server PowerShell – créer une étendue DHCP
Add-DhcpServerv4Scope -Name "VLAN30-WiFi" -StartRange 192.168.30.50 `
    -EndRange 192.168.30.240 -SubnetMask 255.255.255.0

# Windows Server PowerShell – réservation
Add-DhcpServerv4Reservation -ScopeId 192.168.30.0 `
    -IPAddress 192.168.30.10 -ClientId "AA-BB-CC-DD-EE-FF"
```

Administration courante

- Surveiller le taux d'occupation de chaque étendue, signal d'alerte avant épuisement des adresses disponibles
- Vérifier périodiquement la cohérence entre les réservations DHCP et l'inventaire des équipements (Partie I, Chapitre 5)
- Nettoyer les baux expirés et les réservations orphelines (équipements retirés du réseau)

| La règle des 80/20 pour la redondance DHCP

Pour assurer une redondance sans configuration de failover complexe, une pratique éprouvée consiste à répartir chaque étendue entre deux serveurs DHCP selon une règle 80/20 : le serveur principal sert 80 % de la plage, le serveur secondaire sert les 20 % restants. En cas de panne du serveur principal, le secondaire continue de répondre, certes avec une plage réduite, évitant une interruption totale du service.

| Bonnes pratiques

À appliquer systématiquement

- Toujours exclure de la plage DHCP les adresses déjà réservées en statique (Chapitre 8), pour éviter tout conflit
- Ajuster la durée du bail selon le contexte : bail court pour un réseau invité à forte rotation, bail long pour un réseau de postes fixes
- Documenter chaque réservation avec sa justification (Partie I, Chapitre 4)
- Prévoir systématiquement une redondance DHCP dès que le service devient critique pour l'activité (Partie IX)

Erreurs courantes

⚠ À éviter

- Oublier le relais DHCP (ip helper-address) sur un nouveau VLAN, laissant ses équipements sans adresse IP
- Faire chevaucher la plage DHCP avec des adresses statiques déjà attribuées, provoquant des conflits d'adresses
- Déployer un serveur DHCP non autorisé (rogue DHCP), par erreur ou malveillance, qui répond plus vite que le serveur légitime et détourne le trafic (voir sécurité ci-dessous)
- Laisser un bail extrêmement long sur un réseau à forte rotation d'équipements (invités), épuisant inutilement la plage disponible

Dépannage

Symptôme	Cause probable	Vérification
Le poste reçoit une adresse 169.254.x.x (APIPA)	Aucun serveur DHCP accessible, relais manquant	Vérifier le relais DHCP sur le VLAN, la connectivité au serveur
Certains postes reçoivent une IP incohérente avec leur VLAN	Un serveur DHCP non autorisé répond sur le réseau	Rechercher un équipement DHCP rogue (voir sécurité)
L'étendue est épuisée, plus aucune adresse disponible	Trop d'équipements pour la plage définie, ou baux non libérés	Élargir la plage si possible, réduire la durée du bail, nettoyer les baux expirés

Recommandations de sécurité

Sécurité

Un serveur DHCP non autorisé (rogue DHCP), qu'il soit malveillant ou simplement un routeur personnel mal branché par un employé, peut détourner tout le trafic d'un segment en distribuant sa propre passerelle et son propre DNS. Le DHCP snooping, une fonctionnalité disponible sur la plupart des switches manageables, autorise uniquement les ports désignés (côté serveur DHCP légitime) à répondre aux requêtes DHCP, bloquant toute réponse provenant d'un port utilisateur normal.

Cas pratique — Haitech Solutions

Cas pratique

Le plan d'adressage à huit VLAN documenté dans [livrables/reseau/](#) illustre le même principe de séparation entre plage DHCP et adresses statiques que ce chapitre : chaque VLAN à usage dynamique (Administration, Wi-Fi employés, Invités) réserve explicitement ses 50 premières adresses aux équipements statiques (passerelle, switches, serveurs), la plage DHCP démarrant seulement après. Ce même découpage, directement réutilisable, garantit qu'une réservation DHCP ne peut jamais entrer en conflit avec une adresse statique déjà attribuée.

Résumé du chapitre

- Le processus DORA (Discover, Offer, Request, Acknowledge) attribue automatiquement adresse IP et paramètres réseau.
- Le relais DHCP (ip helper-address) est indispensable dès que le serveur DHCP n'est pas sur le même VLAN que ses clients.
- La règle des 80/20 offre une redondance simple sans configuration de failover complexe.

- Le DHCP snooping protège contre les serveurs DHCP non autorisés (rogue DHCP), une menace fréquente et sous-estimée.

Chapitre suivant : le pare-feu, filtrage de trafic et défense périmétrique.

PARTIE III · CHAPITRE 16

Pare-feu : filtrage et défense périmétrique

Rôle du pare-feu

Un pare-feu (firewall) filtre le trafic réseau selon un ensemble de règles, autorisant ou bloquant chaque flux en fonction de critères comme l'adresse source, l'adresse destination, le port, le protocole, et pour les pare-feu modernes, le contenu applicatif lui-même. C'est la pièce centrale de la défense périmétrique, mais aussi, de plus en plus, de la segmentation interne (micro-segmentation, voir Zero Trust en Partie XI).

Fonctionnement : générations de pare-feu

Génération	Principe	Limite
Filtrage de paquets (stateless)	Chaque paquet évalué isolément selon IP/port	Ne comprend pas le contexte d'une connexion, facilement contourné
Stateful (à état)	Suit l'état de chaque connexion (table de sessions), autorise le retour d'une connexion initiée en interne	Standard actuel de base, mais ignore le contenu applicatif

Génération	Principe	Limite
NGFW (Next-Generation Firewall)	Inspection applicative (couche 7), détection d'intrusion intégrée, contrôle par utilisateur/application	Plus coûteux, plus complexe à régler finement

À savoir

Un pare-feu stateful autorise automatiquement le trafic de retour d'une connexion initiée depuis l'intérieur (par exemple la réponse d'un serveur web à une requête d'un poste interne), sans qu'une règle explicite pour ce sens de retour soit nécessaire. C'est cette table d'état qui distingue un pare-feu stateful d'un simple filtre de paquets stateless, où chaque sens de trafic doit être autorisé explicitement.

Prérequis

- Une cartographie des flux réseau nécessaires entre chaque zone (Partie I, Chapitre 3)
- Un plan d'adressage et de segmentation VLAN déjà en place (Partie II)
- Une politique de sécurité définissant le principe par défaut : tout bloquer sauf autorisation explicite (« deny all, permit by exception »), la seule approche recommandée en entreprise

Mise en place d'une politique de pare-feu

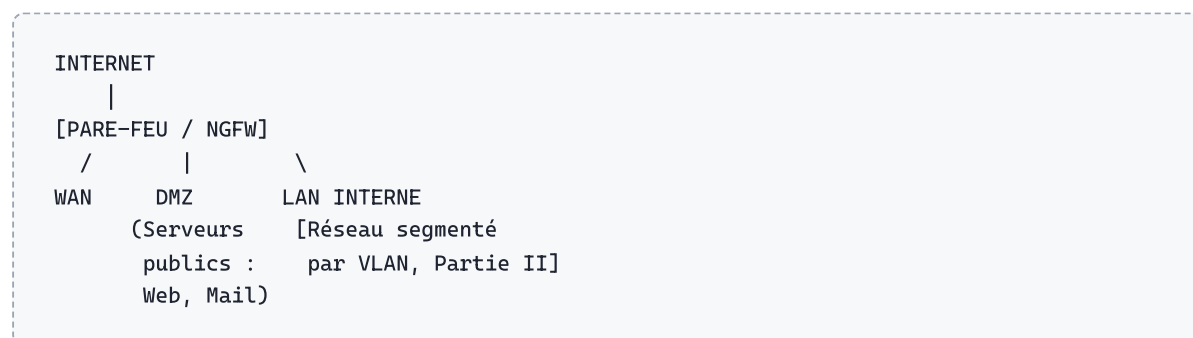
1. **Définir les zones de sécurité** — Interne (LAN), externe (WAN/Internet), DMZ le cas échéant (voir ci-dessous), invités.
2. **Appliquer le principe du refus par défaut** — Bloquer tout le trafic entre zones, puis autoriser explicitement chaque flux nécessaire.
3. **Rédiger les règles du plus spécifique au plus général** — La plupart des pare-feu évaluent les règles dans l'ordre, la première correspondance

l'emporte.

4. **Documenter chaque règle avec sa justification métier** — Aucune règle sans propriétaire ni raison d'être (Partie X, gestion des changements).
5. **Tester chaque règle après application** — Vérifier que le trafic attendu passe, et que le trafic non désiré reste bloqué.
6. **Auditer périodiquement l'ensemble des règles** — Retirer les règles devenues obsolètes (Partie XI).

La DMZ (zone démilitarisée)

Une DMZ est un segment réseau intermédiaire, isolé à la fois du réseau interne et d'Internet, destiné à héberger les services devant être accessibles depuis l'extérieur (serveur web public, serveur de messagerie). Un attaquant compromettant un service en DMZ n'obtient pas automatiquement un accès au réseau interne : la DMZ est reliée séparément au pare-feu, avec ses propres règles de filtrage strictes vers le LAN interne.



Configuration : exemples de règles

```
# Linux nftables – politique par défaut deny, puis autorisations explicites
nft add table inet filtre
nft add chain inet filtre entree { type filter hook input priority 0 \; po
nft add rule inet filtre entree ct state established,related accept
nft add rule inet filtre entree iifname "lo" accept
nft add rule inet filtre entree tcp dport 22 ip saddr 192.168.10.0/24 acce
nft add rule inet filtre entree tcp dport 443 accept

# Cisco ASA – ACL bloquant le VLAN invités vers l'interne
access-list BLOCK-GUESTS extended deny ip 192.168.40.0 255.255.255.0 192.1
access-list BLOCK-GUESTS extended permit ip any any
access-group BLOCK-GUESTS in interface guest-vlan

# MikroTik RouterOS – règle de filtrage forward
/ip firewall filter add chain=forward src-address=192.168.40.0/24 \
    dst-address=192.168.0.0/16 action=drop comment="Invites vers interne : b

# Windows Server – pare-feu local via PowerShell
New-NetFirewallRule -DisplayName "Autoriser RDP depuis Admin" `
    -Direction Inbound -Protocol TCP -LocalPort 3389 `
    -RemoteAddress 192.168.10.0/24 -Action Allow
```

Administration courante

- Revoir la liste complète des règles au moins une fois par trimestre, en confirmant que chacune reste justifiée (Partie X)
- Surveiller les journaux de blocage pour détecter des tentatives d'accès anormales (Partie XI, SIEM)
- Tester le comportement du pare-feu après chaque mise à jour de firmware ou de version, un changement de comportement par défaut est possible

Bonnes pratiques

💡 À appliquer systématiquement

- Toujours partir du principe « tout bloquer, autoriser par exception », jamais l'inverse
- Restreindre chaque règle à la plage IP la plus étroite possible, jamais `any` en source si évitable
- Documenter systématiquement l'auteur, la date et la justification de chaque règle ajoutée
- Séparer les services exposés publiquement dans une DMZ dédiée, jamais directement sur le réseau interne

Erreurs courantes

⚠️ À éviter

- Accumuler des règles temporaires « juste pour ce test » qui ne sont jamais retirées ensuite
- Utiliser `any` en source ou en destination par facilité, élargissant inutilement la surface d'exposition
- Placer une règle générale d'autorisation avant une règle de blocage plus spécifique, la rendant inopérante (ordre d'évaluation)
- Oublier de dupliquer chaque règle IPv4 vers son équivalent IPv6 (Chapitre 9)

Dépannage

Symptôme	Cause probable	Vérification
Un flux légitime est bloqué de façon	Règle générale de blocage évaluée avant la	Vérifier l'ordre des règles, tester en isolant la règle

Symptôme	Cause probable	Vérification
inattendue	règle d'autorisation spécifique	suspecte
Un flux qui devrait être bloqué passe quand même	Règle trop permissive (any) évaluée avant la règle de blocage prévue	Auditer l'ordre et la spécificité de chaque règle
Le pare-feu bloque le trafic de retour d'une connexion légitime	Pare-feu en mode stateless, ou règle de retour manquante	Vérifier le mode stateful et la table d'état des connexions

Recommandations de sécurité

Sécurité

Un pare-feu périmétrique seul ne protège pas contre un déplacement latéral une fois un poste interne compromis. La segmentation interne par VLAN combinée à des règles de pare-feu entre segments (micro-segmentation, voir Zero Trust en Partie XI) limite considérablement la portée d'une compromission initiale. Ne jamais exposer une interface de gestion du pare-feu lui-même sur Internet sans restriction stricte d'IP source et authentification forte.

Cas pratique — Haitech Solutions

✦ Cas pratique

BANKA applique le principe « refus par défaut, autorisation par exception » au niveau applicatif plutôt que réseau : RBAC sur toutes les routes, blocage des transactions sans caisse ouverte, whitelist explicite des droits de mandats. C'est le même raisonnement de sécurité que la règle « deny all, permit by exception » de ce chapitre, appliqué à une autre couche (Partie II, Chapitre 6) : dans les deux cas, la sécurité repose sur une liste positive de ce qui est explicitement autorisé, jamais sur une liste négative de ce qui est explicitement interdit.

Résumé du chapitre

- Un pare-feu stateful suit l'état des connexions ; un NGFW ajoute l'inspection applicative en couche 7.
- Le principe « tout bloquer, autoriser par exception » est la seule approche recommandée en entreprise.
- Une DMZ isole les services exposés publiquement, limitant l'impact d'une compromission de ces services.
- Un audit trimestriel des règles évite l'accumulation de règles obsolètes ou trop permissives.

Chapitre suivant : proxy et reverse proxy.

Proxy et Reverse Proxy

Rôle du proxy et du reverse proxy

Un proxy (proxy direct) intermédie les requêtes **sortantes** d'un réseau interne vers Internet : les postes clients s'y connectent pour accéder au web, plutôt que de sortir directement. Un reverse proxy fait l'inverse : il intermédie les requêtes **entrantes** d'Internet vers un ou plusieurs serveurs internes, se présentant comme le seul point de contact visible depuis l'extérieur. Les deux servent des objectifs très différents malgré la parenté de nom, et les confondre est une source fréquente d'erreur de conception.

Fonctionnement comparé

Aspect	Proxy direct	Reverse proxy
Sens du trafic intermédié	Sortant (interne → Internet)	Entrant (Internet → interne)
Visible pour	Les clients internes (configuré explicitement)	Les clients externes (transparent, ils croient parler au serveur final)
Objectifs typiques	Filtrage web, cache, contrôle d'accès, anonymisation partielle	Répartition de charge, terminaison TLS, cache, masquage de l'architecture interne
Exemples de logiciels	Squid, PfSense (proxy transparent)	Nginx, HAProxy, Traefik, Apache (mod_proxy)

À savoir

Un reverse proxy est aujourd'hui quasiment systématique devant toute application web moderne, même sans besoin de répartition de charge à proprement parler : il centralise la terminaison TLS (un seul certificat à gérer plutôt qu'un par serveur applicatif), ajoute une couche de cache, et masque la topologie interne réelle (l'attaquant externe ne voit que le reverse proxy, jamais directement le serveur applicatif).

Prérequis

- Pour un proxy direct : une politique claire de filtrage web (catégories autorisées/interdites) et un plan pour les exceptions
- Pour un reverse proxy : les serveurs backend déjà déployés et fonctionnels, un certificat TLS valide (Partie XI, PKI)
- Une compréhension des en-têtes HTTP transmis (X-Forwarded-For, X-Forwarded-Proto) pour préserver l'information du client d'origine

Mise en place d'un reverse proxy

1. **Définir la correspondance domaine/chemin → serveur backend** — Quel nom de domaine ou chemin d'URL route vers quelle application interne.
2. **Configurer la terminaison TLS** — Le certificat est installé sur le reverse proxy, le trafic interne vers le backend peut rester en clair (réseau interne de confiance) ou être re-chiffré selon le niveau de sécurité requis.
3. **Transmettre les en-têtes d'origine** — `X-Forwarded-For` (IP réelle du client), `X-Forwarded-Proto` (http/https d'origine), indispensables pour que l'application backend journalise correctement l'origine des requêtes.
4. **Configurer les vérifications de santé (health checks)** — Le reverse proxy doit détecter un backend défaillant et cesser de lui envoyer du trafic (voir Chapitre 19, load balancing).
5. **Mettre en place la mise en cache si pertinent** — Pour les contenus statiques, réduisant la charge sur les serveurs applicatifs.

Configuration : exemples

```
# Nginx – reverse proxy simple avec terminaison TLS
server {
    listen 443 ssl;
    server_name app.otela.ht;
    ssl_certificate      /etc/ssl/certs/app.otela.ht.crt;
    ssl_certificate_key  /etc/ssl/private/app.otela.ht.key;

    location / {
        proxy_pass http://192.168.20.10:3000;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
        proxy_set_header X-Forwarded-Proto $scheme;
    }
}

# Squid – proxy direct, extrait de configuration (filtrage par catégorie)
acl bloque_reseaux_sociaux dstdomain .facebook.com .instagram.com
http_access deny bloque_reseaux_sociaux
http_access allow localnet
http_access deny all

# Traefik – reverse proxy déclaratif via labels Docker (docker-compose.yml)
labels:
- "traefik.http.routers.app.rule=Host(`app.otela.ht`)"
- "traefik.http.routers.app.tls=true"
- "traefik.http.services.app.loadbalancer.server.port=3000"
```

Administration courante

- Surveiller les journaux d'accès du reverse proxy, première source de visibilité sur le trafic entrant réel (Partie X)
- Renouveler les certificats TLS avant expiration, idéalement via un mécanisme automatisé (Let's Encrypt/ACME, Partie XI)
- Vérifier périodiquement que les règles de filtrage du proxy direct restent alignées avec la politique de sécurité de l'entreprise

Bonnes pratiques

💡 À appliquer systématiquement

- Toujours transmettre les en-têtes `X-Forwarded-*` au backend, pour préserver la traçabilité de l'origine réelle des requêtes
- Centraliser la gestion des certificats TLS au niveau du reverse proxy plutôt que de les dupliquer sur chaque serveur applicatif
- Masquer les en-têtes révélant la technologie backend (version de serveur, framework) au niveau du reverse proxy
- Automatiser le renouvellement des certificats plutôt que de compter sur une procédure manuelle

Erreurs courantes

⚠️ À éviter

- Oublier de transmettre `X-Forwarded-For`, rendant tous les journaux applicatifs backend inutilisables pour l'attribution d'une requête (tout apparaît comme venant du reverse proxy)
- Exposer directement un serveur applicatif backend sur Internet en parallèle du reverse proxy, contournant tout le filtrage prévu
- Laisser expirer un certificat TLS faute de suivi, provoquant une interruption de service visible et alarmante pour les utilisateurs
- Confondre proxy direct et reverse proxy dans la conception, créant une architecture qui ne répond ni à l'un ni à l'autre besoin

Dépannage

Symptôme	Cause probable	Vérification
L'application backend journalise l'IP du reverse proxy pour toutes les requêtes	En-tête X-Forwarded-For non transmis ou non lu par l'application	Vérifier la configuration du reverse proxy et le middleware applicatif backend
Erreur de certificat côté client malgré un certificat valide sur le reverse proxy	DNS pointant vers le mauvais serveur, ou cache navigateur	Vérifier la résolution DNS réelle, tester en navigation privée
Le reverse proxy renvoie une erreur 502/504	Backend indisponible ou health check défaillant	Vérifier l'état du serveur backend directement, les logs du reverse proxy

Recommandations de sécurité

Sécurité

Le reverse proxy est un point de centralisation naturel pour la sécurité applicative : limitation de débit (rate limiting), blocage géographique si pertinent, masquage des détails techniques du backend (version, stack). C'est aussi un point de défaillance unique critique s'il n'est pas redondé (Partie IX) — sa panne rend tous les services qu'il dessert inaccessibles simultanément, même si les backends eux-mêmes fonctionnent parfaitement.

Cas pratique — Haitech Solutions

✦ Cas pratique

Le rate limiting appliqué sur les endpoints d'authentification de plusieurs projets du portefeuille (POSTA, LAKAY, GESCOM) illustre une fonctionnalité que ce chapitre recommande de centraliser au niveau du reverse proxy plutôt que de la réimplémenter dans chaque application : sur POSTA, le rate limiter est actuellement en mémoire applicative, ce qui signifie qu'il se réinitialise à chaque redémarrage du processus — un reverse proxy dédié (Nginx avec `limit_req`, ou Traefik) offrirait une limitation de débit persistante et cohérente sur l'ensemble des applications de Haitech Solutions, sans dupliquer cette logique dans chaque backend.

Résumé du chapitre

- Un proxy direct intermédie le trafic sortant ; un reverse proxy intermédie le trafic entrant vers des serveurs internes.
- Le reverse proxy centralise la terminaison TLS, le cache et le masquage de l'architecture interne.
- Transmettre les en-têtes X-Forwarded-* est indispensable pour préserver la traçabilité des requêtes.
- Le reverse proxy, souvent point de défaillance unique, doit être redondé dès que sa criticité le justifie.

Chapitre suivant : le VPN, accès distant sécurisé.

VPN : accès distant sécurisé

Rôle du VPN

Un VPN (Virtual Private Network) établit un tunnel chiffré entre deux points à travers un réseau non maîtrisé (typiquement Internet), donnant l'illusion que les deux extrémités sont sur le même réseau privé. Deux usages dominant en entreprise : le VPN nomade (un télétravailleur accède au réseau interne depuis l'extérieur) et le VPN site-à-site (deux sites d'une même organisation, ou une organisation et un partenaire, sont interconnectés en permanence).

Fonctionnement : les protocoles VPN courants

Protocole	Type	Points forts	Limites
OpenVPN	Nomade et site-à-site	Open source, très éprouvé, flexible	Débit parfois inférieur aux alternatives modernes
WireGuard	Nomade et site-à-site	Très rapide, code source réduit (audit facilité), configuration simple	Écosystème d'outils de gestion encore moins mature qu'OpenVPN
IPSec/IKEv2	Principalement site-à-site	Standard d'entreprise, natif sur la plupart des OS et routeurs	Configuration plus complexe, historiquement plus de problèmes de traversée NAT

Protocole	Type	Points forts	Limites
SSL VPN (souvent via un portail web)	Nomade	Simple pour l'utilisateur final, souvent sans client dédié pour un accès limité	Moins performant qu'un tunnel VPN complet pour un accès réseau étendu

À savoir

WireGuard, plus récent que OpenVPN et IPSec, gagne rapidement du terrain en entreprise grâce à sa simplicité de configuration (une paire de clés publique/privée par pair, sans la complexité de certificats X.509 d'IPSec) et ses performances supérieures, tout en conservant un niveau de sécurité cryptographique considéré comme au moins équivalent aux solutions plus anciennes.

Prérequis

- Une adresse IP publique fixe (ou un nom DNS dynamique) côté serveur VPN
- Un plan d'adressage dédié au réseau VPN, distinct des plages internes existantes (Chapitre 8), pour éviter tout chevauchement
- Une politique d'authentification définie : certificat, clé pré-partagée, ou intégration avec l'annuaire d'entreprise (Partie IV) et idéalement MFA (Partie XI)

Mise en place d'un VPN nomade

1. **Choisir le protocole** — WireGuard pour la simplicité et la performance, OpenVPN si l'écosystème de gestion centralisée existant l'impose.
2. **Définir le plan d'adressage VPN** — Un sous-réseau dédié, non chevauchant avec les VLAN internes.

3. **Configurer l'authentification** — Idéalement couplée à l'annuaire d'entreprise et renforcée par MFA (Partie IV et XI).
4. **Définir les routes poussées au client** — Accès complet au réseau interne (« full tunnel ») ou accès restreint à certains sous-réseaux seulement (« split tunnel »), selon la politique de sécurité.
5. **Documenter et distribuer la configuration client** — De façon sécurisée, jamais par un canal non chiffré (email en clair).

Mise en place d'un VPN site-à-site

1. **Vérifier la compatibilité des équipements aux deux extrémités** — Même protocole supporté des deux côtés.
2. **Vérifier l'absence de chevauchement d'adressage IP entre les deux sites** — Un chevauchement rend le VPN inutilisable sans renumérotation (Chapitre 8).
3. **Configurer le tunnel avec authentification mutuelle** — Certificat ou clé pré-partagée robuste, jamais un mot de passe faible.
4. **Configurer les routes statiques ou le routage dynamique** — Vers le réseau distant, à travers le tunnel (Chapitre 12).
5. **Tester la bascule en cas de coupure** — Si un lien VPN de secours existe, vérifier le basculement automatique.

Configuration : exemples

```
# WireGuard - configuration serveur (wg0.conf)
[Interface]
Address = 10.10.0.1/24
ListenPort = 51820
PrivateKey = <cle-privee-serveur>

[Peer]
PublicKey = <cle-publique-client>
AllowedIPs = 10.10.0.2/32

# WireGuard - configuration client
[Interface]
Address = 10.10.0.2/24
PrivateKey = <cle-privee-client>

[Peer]
PublicKey = <cle-publique-serveur>
Endpoint = vpn.otela.ht:51820
AllowedIPs = 192.168.0.0/16, 10.10.0.0/24
PersistentKeepalive = 25

# MikroTik RouterOS - VPN WireGuard
/interface wireguard add name=wg0 listen-port=51820
/ip address add address=10.10.0.1/24 interface=wg0
/interface wireguard peers add interface=wg0 \
    public-key="<cle-publique-client>" allowed-address=10.10.0.2/32
```

Administration courante

- Réviser périodiquement la liste des accès VPN actifs, en particulier après le départ d'un collaborateur (Partie IV)
- Surveiller les journaux de connexion VPN pour détecter des connexions depuis des localisations inhabituelles (Partie XI)
- Vérifier la performance du tunnel (latence, débit) périodiquement, en particulier pour les VPN site-à-site supportant des applications sensibles à la latence

Bonnes pratiques

À appliquer systématiquement

- Toujours privilégier un split tunnel plutôt qu'un full tunnel quand seul un accès à des ressources internes spécifiques est nécessaire, réduisant la charge et la surface d'exposition
- Coupler systématiquement l'authentification VPN à un second facteur (MFA, Partie XI) pour tout accès nomade
- Révoquer immédiatement les accès VPN au départ d'un collaborateur, comme tout autre accès (Partie IV)
- Utiliser des clés/certificats individuels par utilisateur ou équipement, jamais une configuration partagée entre plusieurs personnes

Erreurs courantes

À éviter

- Chevaucher le plan d'adressage VPN avec un VLAN interne existant, rendant certaines destinations injoignables une fois le tunnel actif
- Utiliser un full tunnel par défaut sans réflexion, alors qu'un split tunnel suffirait et réduirait la charge sur le VPN
- Laisser un accès VPN actif après le départ d'un collaborateur ou la fin d'une mission de prestataire
- Négliger la mise à jour du logiciel VPN, une vulnérabilité sur un composant VPN expose potentiellement tout le réseau interne

Dépannage

Symptôme	Cause probable	Vérification
Le tunnel VPN s'établit mais aucun trafic ne passe	Route manquante côté serveur ou client, ou pare-feu bloquant le trafic post-tunnel	Vérifier les routes et les règles de pare-feu sur les deux extrémités
Certaines destinations internes sont injoignables via VPN	Chevauchement d'adressage, ou AllowedIPs/split tunnel mal configuré	Vérifier le plan d'adressage VPN et la configuration des routes poussées
Connexion VPN instable, coupures fréquentes	Problème de MTU sur le tunnel, ou NAT traversal mal négocié	Ajuster la MTU du tunnel (Chapitre 7), vérifier le NAT en amont

Recommandations de sécurité

Sécurité

Le VPN reste l'une des cibles privilégiées des attaquants pour obtenir un accès initial au réseau interne : identifiants volés, logiciel VPN non mis à jour, ou configuration sans MFA sont des vecteurs d'attaque récurrents constatés dans de nombreux incidents publics. Traiter l'accès VPN avec la même rigueur qu'un compte administrateur (Partie I, Chapitre 2) : MFA obligatoire, révision périodique des accès actifs, journalisation systématique des connexions.

Cas pratique — Haitech Solutions

✦ Cas pratique

Le module dial-in téléphonique de REYINYON, bien que non centré sur un VPN classique, illustre le même principe de pont sécurisé entre un réseau externe non maîtrisé (le réseau téléphonique public via Twilio) et l'infrastructure interne (LiveKit) : la signature des requêtes Twilio est vérifiée côté serveur avant tout traitement, exactement comme un VPN authentifie chaque pair avant d'accepter le trafic. Le futur pont SIP vers LiveKit, documenté mais non encore codé, nécessitera précisément ce type de raisonnement — IP publique, TLS, authentification mutuelle — que ce chapitre applique au VPN classique.

Résumé du chapitre

- Le VPN nomade connecte un utilisateur distant au réseau interne ; le VPN site-à-site interconnecte deux réseaux en permanence.
- WireGuard s'impose de plus en plus pour sa simplicité et ses performances, sans sacrifier la sécurité.
- Le split tunnel limite la charge et la surface d'exposition par rapport à un full tunnel systématique.
- L'accès VPN doit être traité avec la même rigueur qu'un accès administrateur : MFA, révision périodique, révocation immédiate au départ.

Chapitre suivant : la répartition de charge (load balancing).

Load Balancing : répartition de charge

Rôle du load balancing

La répartition de charge (load balancing) distribue le trafic entrant entre plusieurs serveurs backend identiques, poursuivant simultanément deux objectifs : la performance (aucun serveur unique n'absorbe toute la charge) et la haute disponibilité (la panne d'un serveur backend n'interrompt pas le service, le répartiteur cesse simplement de lui envoyer du trafic). C'est un complément direct du reverse proxy (Chapitre 17), souvent porté par le même composant logiciel.

Fonctionnement : niveaux et algorithmes

Niveau	Couche OSI	Principe	Cas d'usage
L4 (transport)	4	Répartit selon IP/port, sans lire le contenu applicatif	Trafic générique TCP/UDP, très haute performance
L7 (application)	7	Répartit selon le contenu HTTP (chemin d'URL, en-têtes, cookies)	Applications web, routage fin par service

Algorithmes de répartition courants

Algorithme	Principe	Cas d'usage
Round robin	Distribution cyclique, un serveur après l'autre	Backends de capacité homogène
Least connections	Envoie vers le serveur ayant le moins de connexions actives	Charges de durée variable (certaines requêtes plus longues que d'autres)
IP hash	La même IP source est toujours dirigée vers le même serveur	Sessions applicatives sans état partagé entre serveurs (sticky session)
Pondéré (weighted)	Distribution proportionnelle à une capacité déclarée par serveur	Backends de capacités matérielles différentes

À savoir

Une « sticky session » (session collante) force toutes les requêtes d'un même utilisateur vers le même serveur backend pendant la durée de sa session, généralement via un cookie ou l'IP hash. C'est une solution pragmatique quand l'état de session est stocké localement sur chaque serveur plutôt que partagé (Redis, base de données) — mais elle limite l'efficacité de la répartition et complique la bascule en cas de panne du serveur concerné. La solution structurellement plus robuste est une application sans état (stateless), où n'importe quel serveur peut traiter n'importe quelle requête.

| Prérequis

- Au moins deux instances backend identiques et interchangeables

- Une stratégie claire sur l'état applicatif : partagé (session en base/cache commun) ou local (nécessitant des sticky sessions)
- Un mécanisme de vérification de santé (health check) fiable pour chaque backend

Mise en place d'un répartiteur de charge

1. **Déployer au moins deux instances backend identiques** — Version, configuration et accès aux mêmes données strictement identiques.
2. **Choisir le niveau et l'algorithme** — L7 avec least connections pour la majorité des applications web modernes.
3. **Configurer les vérifications de santé** — Un endpoint dédié (`/healthz`) que le répartiteur interroge périodiquement, retirant automatiquement un backend en échec.
4. **Décider de la gestion de session** — Stateless recommandé ; sticky sessions en solution de repli si nécessaire.
5. **Tester la bascule** — Arrêter volontairement un backend et vérifier que le service reste disponible sans interruption perceptible.

Configuration : exemples

```
# HAProxy – répartition L7 avec vérification de santé
frontend front_web
    bind *:443 ssl crt /etc/ssl/certs/app.pem
    default_backend back_web

backend back_web
    balance leastconn
    option httpchk GET /healthz
    server app1 192.168.20.10:3000 check
    server app2 192.168.20.11:3000 check
    server app3 192.168.20.12:3000 check backup

# Nginx – répartition simple round robin avec health check passif
upstream backend_pool {
    least_conn;
    server 192.168.20.10:3000 max_fails=3 fail_timeout=30s;
    server 192.168.20.11:3000 max_fails=3 fail_timeout=30s;
}

server {
    listen 443 ssl;
    location / {
        proxy_pass http://backend_pool;
    }
}
```

Administration courante

- Surveiller la distribution réelle de charge entre backends, un déséquilibre persistant indique souvent un problème de configuration ou un backend sous-dimensionné
- Vérifier périodiquement que les health checks reflètent réellement l'état de santé applicatif (pas seulement « le port répond », mais « le service fonctionne »)
- Tester régulièrement la procédure de retrait planifié d'un backend (pour maintenance), sans coupure de service

Bonnes pratiques

À appliquer systématiquement

- Concevoir les applications de façon stateless dès que possible, plutôt que de compenser par des sticky sessions
- Utiliser un endpoint de health check applicatif réel (vérifiant la connectivité base de données, par exemple), pas uniquement une réponse HTTP 200 statique
- Tester la bascule automatique en environnement de pré-production avant de faire confiance à la haute disponibilité en production
- Dimensionner le nombre de backends avec une marge permettant d'absorber la perte d'au moins une instance sans dégradation perceptible (N+1 minimum)

Erreurs courantes

À éviter

- Un health check qui vérifie uniquement que le port TCP répond, sans jamais détecter qu'un service est bloqué ou en erreur applicative
- Déployer des backends avec des versions de code différentes entre eux, provoquant un comportement incohérent selon le serveur qui répond
- Ignorer la latence introduite par le répartiteur lui-même, qui devient à son tour un point de défaillance unique s'il n'est pas redondé (Partie IX)
- Confondre répartition de charge et haute disponibilité complète : répartir la charge entre plusieurs instances applicatives ne protège pas automatiquement une base de données unique en amont

Dépannage

Symptôme	Cause probable	Vérification
Un utilisateur perd sa session en cours de navigation	Absence de sticky session alors que l'état est stocké localement sur chaque serveur	Vérifier la stratégie de gestion d'état, envisager un état partagé (Redis)
Un backend continue de recevoir du trafic malgré une panne	Health check insuffisant, ou intervalle de vérification trop long	Resserrer l'intervalle de vérification, approfondir le contenu du health check
La charge reste concentrée sur un seul backend	Algorithme mal choisi (IP hash avec peu de clients distincts), ou poids mal configuré	Revoir l'algorithme de répartition et les poids déclarés

Recommandations de sécurité

Sécurité

Le répartiteur de charge, en position frontale, est un point naturel pour appliquer une limitation de débit (rate limiting) et un filtrage de base contre les attaques par déni de service applicatif, en complément du pare-feu périmétrique (Chapitre 16). Comme pour le reverse proxy, sa propre disponibilité doit être assurée (Partie IX) : sa panne rend indisponible l'ensemble des backends qu'il dessert, même s'ils fonctionnent tous parfaitement.

Cas pratique — Haitech Solutions

✦ Cas pratique

REYINYON a été testé avec deux instances backend Socket.io séparées derrière un adapter Redis pour le scaling horizontal, une architecture directement comparable à un déploiement multi-backend derrière un répartiteur de charge : l'état des connexions temps réel (qui est connecté à quelle réunion) est partagé via Redis plutôt que stocké localement sur chaque instance, permettant à n'importe quelle instance de traiter n'importe quel client — exactement le principe stateless recommandé dans ce chapitre plutôt que de dépendre de sticky sessions.

Résumé du chapitre

- Le load balancing répartit le trafic entre plusieurs backends identiques, pour la performance et la haute disponibilité simultanément.
- L4 répartit sans lire le contenu applicatif ; L7 permet un routage fin selon le contenu HTTP.
- Une architecture stateless est structurellement plus robuste qu'une dépendance aux sticky sessions.
- Le répartiteur de charge lui-même doit être redondé, sous peine de devenir un nouveau point de défaillance unique.

Ceci conclut la Partie III. Partie suivante : identité, annuaire et contrôle d'accès (Active Directory, Entra ID, LDAP, GPO, Kerberos).